Threat Intelligence

Threat evolution in Q3 2020

October 2020

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Ransomware 5

Threats to the government sector 6

Data leaks 7

FORECASTS FOR Q4 2020 **8**

ADVANCED THREATS IN THE FINANCIAL SECTOR **9**

FINANCIAL THREATS **14**

Malware for Android 15

Threats and malware for PC 17

Attacks on ATMs and POS terminals 29

RANSOMWARE **30**

STATE-SPONSORED APTS **44**

DATA LEAKS **68**

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends, and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats, and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages, and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q3 2020 saw the following APT campaigns against financial organizations:

- Tirion, a previously unknown tool associated with the Fin7 threat group was discovered.
- Lazarus (North Korea) used multiple platforms — called Dorusio Wallet and Cryptoistic — that imitated cryptocurrency trading applications. The hackers also used web skimmers to steal bank card data and replaced Bitcoin wallets during payments on government services websites. In addition, US-CERT gave their own name to the group, BeagleBoyz, and described some of the group's tools: ECCENTRICBANDWAGON, VIVACIOUSGIFT, and FASTCASH for Windows designed for attacks on the financial sector.
- The hacker group Evilnum buys tools from Golden Chickens, a group that offers malware as a service. Evilnum has targeted financial technology companies and their customers in Europe, Canada, and Australia since 2017. In addition, the hackers used a new remote access Trojan (RAT) called PyVil.

Financial threats

- Group-IB specialists analyzed Eventbot, a new Android bot that targets financial applications in Italy, the United Kingdom, Spain, Switzerland, France, and Germany; crypto wallets are also targeted.
- Anubis malware was used in attacks against the customers of Russian banks. In addition to Russia, the malware was active in Europe, Japan, Turkey, and Australia.
- FlexNet remains the most active banking Trojan in the Commonwealth of Independent States (CIS).
- The source code of the Android banking Trojan Cerberus v.2, which was put up for sale six months ago, was made publicly available.
- The new Android bot Thiefbot was put up for sale on underground forums. Its targets are the customers of Turkish banks.
- Russia's Central Bank detected a new way of stealing money from bank accounts involving the Faster Payments System (FPS). During the integration of the FPS in one financial organization's mobile banking service, an API vulnerability was left and fraudsters could substitute sender accounts, since the sender address was not checked because of the vulnerability. Fraudsters made transfers on their own behalf but instead of their account number (where money should have been taken from) they put the account numbers of their victims. As a result, the automated banking system processed transfers from someone else's account to the fraudsters' account.
- Qbot was highly active and attacked banks in the United States and Canada.
- We continue observing RTM attacks against legal entities in the CIS.
- The banking Trojan zLoader was used in attacks against financial organizations in the US, Canada, Germany, and the UK. As payload, zLoader installed Cobalt Strike and Gazavat.
- Danabot continued attacks against banks in Australia, Poland, and Germany.
- The Ramnit Trojan continues to be highly active in Japan and Europe.
- Grandoreiro, Javali, Melcoz, and Guildma Trojans are active in Latin America.
- We did not record any activity of the Backswap Trojan.
- Trickbot continues to be used in attacks on banks in North America, Europe, Japan, and Australia; however, its focus is gradually shifting to being involved in ransomware attacks.

- ISFB was active in Australia and Spain.
- IcedID was active in the US and Canada.
- Among POS Trojans, Magic POS, Posnewt, Rawpos, Posfight, Hydrapos, and Gorynych were active. These malicious programs are not new, they emerged in 2015–2016 and have since been used to compromise card dumps.
- Group-IB specialists' analysis of the card shops Findsome, Bestvalid, and Entershop revealed large volumes of compromised bank card data from the following areas: Western Asia (50,000 cards), Saudi Arabia (16,000 cards), Latin America (over 17,000 cards). This data includes CC (textual bank card data that includes the full card number, expiration date, and CVV/CVC code) rather than dumps. This means that infected POS terminals were not involved in the compromise of the cards and the source of the breach was not established.
- Group-IB specialists continue observing high activity of JavaScript (JS) sniffers (Inter, Poter, CoffeeMokko).
- Group-IB specialists detected and analyzed the activity of the UltraRank threat group, which uses JS sniffers such as FakeLogistics, WebRank, and SnifLite. The group has been active since at least 2015.
- In late September, a threat actor with the nickname kirilnefimov made a post about selling the source code of ATM malware on an underground forum. At the moment, Group-IB specialists are in search of additional information about this threat, but there are suggestions that the seller does not deliver on their promises.
- Multiple new services for selling access to corporate networks appeared on underground forums; the author of the posts are threat actors with the nicknames vasyldn and drumrlu. The sellers might be linked.
- A new RAT-type program called BitRAT was put up for sale in the underground.

Ransomware

Ransomware has become the biggest threat out there: we receive information about major incidents on a daily basis. Currently, we see that threat groups specifically target major companies with large revenues, which allows threat actors to demand significant ransoms for decrypting data.

This report covers only some of the incidents that have occurred.

- One of the most serious ransomware attacks during the reporting period was an incident at Garmin involving the WastedLocker malware.
- The threat groups Netwalker, Revil (Sodinokibi), Nefilim, Maze, DoppelPaymer, and LockBit were active and attacked a big number of companies worldwide.
- Universal Health Services (UHS), a Fortune 500 company that manages about 400 medical facilities in the US, the UK, and Puerto Rico fell victim to an attack involving the Ryuk ransomware.
- In August, Konica Minolta, a company, suffered an attack involving the RansomEXX (Defray) ransomware. In September, the ransomware was presumably used in an attack on the Ukrainian company SoftServe.
- Though to a lesser extent, the group that uses the Clop ransomware was active during the reporting period (five companies were attacked).
- The RagnarLocker ransomware attacked the following companies: Bailey&Galyen Attorney at Law, Mapfree, and CMA CGM.
- SunCrypt, lesser-known ransomware, was also active. It is believed that SunCrypt operators cooperate with Maze.
- The new ransomware AgeLocker attacked QNAP's NAS devices and stole data.

- A new ransomware partner program called Avaddon emerged.
- In late August, a file called "lazertag.bin" was uploaded to VirusTotal. Analysis of the file revealed that it was packed using the same packer as that of some of the CobInt stager samples discovered earlier and attributed to the Cobalt threat group. The unpacking of the file revealed the Thanos ransomware targeted at a US construction company. It is not possible to neither definitively say that the packer is a unique tool of Cobalt nor attribute the attack to this group.

Threats to the government sector

Q3 2020 saw the discovery of the following APT campaigns against government organizations:

- Previously unknown malware called Drovorub, which is designed for Linux and associated with the APT28 group (Russia), was discovered. APT28 also carried out a campaign that involved NATO training materials as a lure. The hackers used a Delphi version of the Zebrocy malware.
- The RedDelta threat group (China) was identified. The group has been conducting attacks against law enforcement agencies, religious organizations, and government bodies since 2020.
- Operation PowerFall against a South Korean organization was discovered. The DarkHotel group (North Korea) may be behind it.
- Turla, a Russian threat group, attacked a government organization in the European Union using a new tool called NewPass.
- Attacks against organizations involved in COVID-10 vaccine development were discovered in Canada, the US, and the UK. The attacks involved the WellMess and WellMail malware.
- Our system for early detection of malicious infrastructures continues to detect hosts with the Cobalt Strike framework, used by the OceanLotus group (Vietnam).
- Additional information on the attacks of APT34 (Iran) against telecommunications companies in early 2020 was discovered. The attacks took place in the Middle East and involved both publicly available tools and the custom RDAT tool, which helped researchers attribute the attacks to APT34. In addition, a campaign called Rampant Kitten was revealed; we attribute it to APT34.
- To achieve its goals, the APT35 group (Iran) contacts its victims directly on LinkedIn and WhatsApp and sends links to compromised websites with fake authentication forms.
- Lazarus (North Korea) carried out multiple espionage campaigns, including against the Korean Academy of Medical Sciences and manufactures of military equipment for anti-aircraft warfare and missile defense. The group also used the VHD ransomware.
- Transparent Tribe hackers (Pakistan) went back to using the Crimson Trojan; in particular, its USBWorm module, designed for stealing files from removable drives. In addition, the group used a modified version of the AhMyth Android RAT for espionage against the Indian military.
- The StrongPity group (Turkey) expanded its cyber espionage activities to organizations on most continents.
- APT15 (China) used four new malicious programs (SilkBean, DoubleAgent, CarbonSteal, and GoldenEagle) as part of a yearslong espionage campaign against Uighurs.
- Kimsuky hackers (North Korea) carried out another campaign posing as the Korea Institute for National Unification (KINU).
- APT37 (North Korea) carried out an active reconnaissance campaign against targets in South Korea and the Asia-Pacific region and does not slow down.
- Group-IB experts discovered RedCurl, a previously unknown threat group. The threat actors have been carrying out espionage campaigns in Russia, Ukraine, Canada, Germany, the UK, and Norway since 2018.

- The US government imposed sanctions against APT39 (Iran). They affect 45 associated individuals and one front company, which acts in the interests of Iran's Ministry of Intelligence. The Federal Bureau of Investigation (FBI) detailed multiple sets of malware used by this threat group.
- Gaza Cybergang hackers (Gaza) carried out a new espionage campaign, this time using a malicious Android app called Welcome Chat.
- An unidentified Chinese APT is using a new variant of MgBot to attack targets in India and Hong Kong.
- The Gamaredon group (Russia) continued its attacks against Ukraine's Security Service and Ministry of Foreign Affairs. In addition, an email to the Prosecutor's Office of the Autonomous Republic of Crimea was detected. This may have been an attempt to proxy a malware mailout through automatic forwarding to the current standard address of the Prosecutor General's Office of Ukraine.
- APT40 (China) carried out a malicious campaign using 18 Azure Active Directory applications to attack Microsoft Azure customers.
- APT41 (China) continued being active using a new version of ShadowPad and previously unknown Trojans xDll and SkinnyD. In addition, the US government filed charges against five Chinese nationals suspected of being part of the APT41 group. Two Malaysian businessmen were charged for conspiring with the group.
- A previously unknown group called ReconHellcat conducted malicious campaigns using the BlackWater Trojan against defense and diplomatic organizations in Bulgaria and Azerbaijan.
- A new version of the Bisonal Trojan was used by Tonto Team hackers (China) in attacks against military and financial organizations in Eastern Europe.
- An unidentified group carries out targeted attacks against Indian government agencies using the Indian government's Parichay SSO platform as a lure.
- The TA413 group (China) attacked legislative and diplomatic entities within Europe as well as the Tibetan community. During their attacks, the threat actors employed various malware: the traditional tools ExileRAT and LuckyCat and new malware called Sepulcher.
- Machete hackers were successful in stealing Venezuelan military secrets using the Fpyark Trojan.
- Chinese hackers continue to use an updated version of the Taidoor RAT, which was initially developed in 2008, in their attacks.

Data leaks

- The customer database of a major US IT company was put up for sale on an underground forum. According to the information provided, the database appears to belong to Citrix Systems, Inc.
- In July, the financial company Dave informed its customers about a data leak. Data on a total of 7,516,625 users, which included real names, phone numbers, email addresses, dates of birth, and home addresses, was published online.
- In July, CouchSurfing, a homestay service, suffered a breach of data on 17 million users.
- Security researcher Bob Diachenko discovered yet another unprotected client database of Razer, a gaming equipment manufacturer. The database affected 100,000 customers and included full names, email addresses, phone numbers, order details, and billing and shipping addresses.
- In late September, a 42.9-GB torrent file, which included source code for several operating systems, including Windows XP and Windows Server 2003, was published online.
- Ata Hakcil, a security researcher at WizCase, discovered that Microsoft had accidentally left one of Bing's backend servers exposed online. The server is believed to have exposed more than 6.5

TB of log files containing 13 billion records originating from the Bing search engine. The problem has since been fixed.

- An exposed repository belonging to the Indian state of Uttar Pradesh was discovered. The repository contained data on eight million people tested for COVID-19.
- Researchers at vpnMentor discovered data on over 20 million users of free VPN services exposed online.

Forecasts for Q4 2020

- We believe that ransomware will be the most relevant threat to companies in the next quarter. We are currently seeing a spike in the number of ransomware programs and related partner programs; we are also noticing that threat groups are actively collaborating with services for selling instances of access to corporate networks and cooperating with groups that used to deal with banking Trojans.
- Groups such as RedCurl, which specialize in corporate espionage, have been employing techniques to cover their tracks, including through the use of legitimate tools that are hard to detect. Despite the lack of direct financial damage, which is caused by financially motivated cybercriminal groups, the consequences of espionage activities may amount to millions of dollars.
- Users cannot protect themselves against the fraud scheme involving the Faster Payments System, but we urge banks to conduct independent security assessments of their mobile applications and integrate behavioral analysis systems.
- Lazarus will continue its attacks against both the government and financial sectors as well as cryptocurrenies using PowerBrace, PowerTask, and Dacls RAT.
- The publication of the Cerberus v2 source code in the public domain will result in an increased number of modifications and the sale of “new” malware in big quantities.
- Credit card sniffers will remain a relevant threat. Group-IB specialists continue to detect infections on many websites. We have also seen a rise in the number of groups that use this tool in their attacks.
- Qbot, Icedid, and Trickbot will remain a relevant threat to the banking sector in North America.
- We believe that the Android banking Trojan Anubis will be highly active in Russia, Europe, Asia, and the Americas.
- Eventbot will be employed in attacks against mobile banking users in Europe.
- zLoader will be a relevant threat to banking customers in Europe and North America.
- We believe that the activity of RTM will gradually decrease.
- Gozi will be active in Australia and Italy, while Ramnit will be operating in Japan and Italy.

Advanced threats in the financial sector

333

APT name	Regions attacked	Operation start
FIN7	-	May 2020

In July 2020, cybersecurity researchers published information about a previously unknown tool called Tirion, used by the Fin7 group.

The malware is believed to have been developed to replace the Carbanak backdoor. Tirion is capable of collecting information, executing code, conducting reconnaissance, and moving laterally across a victim's network. Most of the functions are implemented as separate plugins, which are loaded using the reflective loading method.

Tirion supports the following functionality:

- Information gathering
- Screenshot taking
- Listing of running processes
- Command/code execution
- Process migration
- Mimikatz execution
- Password grabbing
- Active Directory and network recon

Tirion consists of three components:

- Loader. This component executes commands from the server and sends responses to it. When attackers want to run a function on a victim machine, they load the related plugin reflectively and execute it filelessly. The traffic between the server and the loader is encrypted with a key that is generated in advance.
- Client
- Server

Researchers discovered PswInfoGrabber, a plugin used for stealing confidential information from victim machines, browser and email passwords in particular.

Fin7 is a financially motivated Russian-speaking threat group active since 2015. The threat actors use social engineering techniques and periodically update their attack methods and tools in an effort to bypass detection mechanisms. Most of their attacks target hospitality and restaurant businesses in Europe and the United States.

APT name	Regions attacked	Operation start
Lazarus	Global	May 2020

Lazarus created yet another cryptocurrency trading program, which installs a backdoor on victim Windows machines. Analysis revealed that it closely resembles a previous operation that involved the AppleJeus cryptocurrency trading malware as well as JMT Trader, Union Crypto Trade, Coin Go Trade, and Kupay Wallet.

This time the program is called Dorusio Wallet. The hackers developed a website where they promote the program (hXXps://dorusio[.]com/).

In addition, it was detected that the RATv3.ps backdoor (also known as PowerBrace), which we reported on back in January 2019, was used.

This malware collects various types of information about the operating system and sends it to a command and control (C&C) server. This information includes:

- Internal IP address
- Computer name
- User name
- Operating system (OS) version
- OS architecture
- Proxy status
- Proxy server
- Script path
- Last bootup time
- OS signature
- OS language
- OS country code
- Primary C&C address and port
- Secondary C&C address and port
- 32/64-bit system

Specialists at Sansec reported about a large-scale malicious campaign aimed at stealing the payment card details of major European and US retailers' customers. The threat actors, who the researchers deem to be the Lazarus group, used legitimate websites to steal credit card data and conceal their activities.

According to the experts, web skimmers were loaded from domains that had been used by the threat actors in successful phishing attacks. Dozens of stores fell victim, including major companies such as Claire's, Wongs Jewellers, Focus Camera, Paper Source, Jit Truck Parts, CBD Armour, Microbattery, and Realchems.

Group-IB specialists' analysis revealed additional domains used in the campaign. We also discovered code for substituting the recipient address during BTC payments, which we dubbed Lazarus BTC Changer. It was detected on a website that sold chemical products and on an Italian online clothes store, both of which accepted BTC payments.

Another attack involving a crypto trading application was discovered in July 2020. In early May 2020, a crypto trading Trojan called Cryptoistic appeared on VirusTotal. Cryptoistic is written in Swift; however, a lot of its code is bridged to Objective C, which could suggest that the developer was more familiar with the older programming language.

The main purpose of Cryptoistic is to entrap users into creating a single account on a fake platform, which can be used to manage multiple accounts on legitimate platforms such as kraken.com, huobi.por, and binance.com.

Perhaps the most interesting of all is the hardcoded URL http://applepkg.com/product/new/iContact.pkg, which despite the .pkg suffix in fact returns Mach-O payload and drops it at /tmp/.signal_tmp.

The iContact binary appears to be a backdoor that gathers user and local data and engages in encrypted communications with a C&C server over TCP. The functionality includes sending and receiving files and running custom commands such as scanning a directory and deleting files.

On August 26, 2020, the FBI, the US Department of Defense, and the Cybersecurity and Infrastructure Security Agency of the Department of Homeland Security (DHS CISA) released information about two malicious programs attributed to the North Korean threat group Lazarus; the organizations also provided information on the FASTCASH Trojan for Windows. Most of these malicious programs had already been detected in earlier attacks.

In addition, US-CERT named the group of North Korean hackers behind attacks on financial organizations BeagleBoyz. BeagleBoyz is tracked in the industry as APT38 (FireEye), Bluenoroff (Kaspersky), Lazarus Group (ESTSecurity), Lazarus (Group-IB), and Stardust Chollima (CrowdStrike).

ECCENTRICBANDWAGON is a family of malware that is used as a reconnaissance tool.

VIVACIOUSGIFT is a network proxy tool. The proxy requires an encrypted command line argument for its source and destination Internet Protocol (IP) addresses and has C&C functionality to retrieve and set the destination IP. The command line argument can also contain a source proxy IP, port, and password. The source proxy is used as an additional proxy when communicating with the source IP. The library libcurl version 7.94.1 is used when communicating with the source proxy. Group-IB has known about VIVACIOUSGIFT under the name Client_TrafficForwarder since 2016.

FASTCASH for Windows. This submission included two unique files. The first file is a malicious application, which can be utilized to inject a dynamic link library (DLL) into a remote Windows process. The second file is a malicious Windows DLL. The DLL contains two functions that can hook callbacks to the Windows application programming interfaces (APIs) "Send" and "Recv" within a targeted process. These hook functions are utilized to intercept traffic received by the target process. In received Financial Messages, the malicious functions will look for targeted Primary Account Numbers (PAN) to deliver a custom response. It appears the malware will target a system on a bank infrastructure, which is designed to process automated teller machine (ATM) transactions.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group's members are from North Korea.

APT name	Regions attacked	Operation start
Evilnum (aka Jointworm)	Europe, UK, Canada, Australia, Cyprus, USA, Czech Republic	2017

Cybersecurity specialists discovered spyware called Evilnum, which targets financial technology companies and their customers, and released information about a similarly named threat group, active since 2017.

According to the researchers, most of Evilnum's targets are located in EU countries and the UK, with several attacks detected in Canada and Australia.

The Evilnum Trojan is designed to steal various types of confidential data. The group tries to penetrate into corporate networks, gain access to accounts, and steal valuable financial information, which can later be used to make fraudulent purchases or can be sold wholesale to other threat actors. In particular, Evilnum is interested in:

- Customer credit card information and proof of address/identity documents
- Spreadsheets and documents with customer lists, investments, and trading operations
- Internal presentations
- Software licenses and credentials for trading software/platforms
- Email credentials

In addition, Evilnum operators can gain access to IT-related information such as VPN configurations.

According to the experts, the Golden Chickens hacker group, which is a Malware-as-a-Service (MaaS) provider, is behind the development of the Trojan for the Evilnum group. Golden Chickens' infamous customers include FIN6 and Cobalt.

An Evilnum attack usually develops as follows: a user receives a phishing email containing a link to a ZIP file hosted on Google Drive. The archive contains several LNK (shortcut) files that extract and execute a malicious JavaScript component, while displaying a decoy document.

The emails target technical support specialists and account managers. The documents used as decoys are mostly photos of credit cards, identity documents, or bills with proof of address, as many financial institutions require these documents from their customers (this is known as "Know Your Customer").

The opening of a malicious document by the victim launches the Evilnum malware, Python-based tools, and Golden Chickens components.

After the researchers' report was released, the Evilnum group deployed a Python-based remote access Trojan (RAT) called PyVil, in addition to changing their infection chain.

The hackers started using a JavaScript dropper to deliver malware in the form of modified versions of legitimate executables to avoid detection by security tools.

The ddpp.exe loader unpacks shellcode that connects to the C&C server and receives a second encrypted executable called "fplayer.exe," which functions as a downloader for the next stage of the Python-based Trojan.

The functionality of PyVil RAT includes:

- Keylogger
- Running cmd commands
- Taking screenshots
- Downloading more Python scripts for additional functionality
- Dropping and uploading executables
- Opening an SSH shell
- Collecting information such as:
    - Anti-virus products installed
    - USB devices connected
    - Chrome version

Financial threats

Malware for Android

Threat name	Detection	Regions attacked
EventBot	March 2020	Italy UK Spain Switzerland France Germany

This malware was discovered in March 2020. No posts about the sale of EventBot were found on underground forums. The malware targets the users of over 200 financial applications, mostly Spanish and Italians ones. EventBot functionality includes interception of input data and SMS messages, execution of web injects, and use of autofill features through Accessibility Service.

The malware is usually disguised on victim mobile phones as Adobe Flash Player, Microsoft Word, or YouTube.

Threat name	Detection	Regions attacked
Source code of Cerberus v2	April 2020	Global

In April 2020, a user with the nickname ANDROID made a post on XSS.is, an underground forum, about renting out an updated version of the Android banking Trojan Cerberus.

The updated Cerberus version can send and intercept SMS messages, show web fakes to the user, record keystrokes (keylogger), launch applications installed on the device, bypass security restrictions and antiviruses, create fake PUSH notifications, and open URLs in the browser.

This malware is an updated version of the Cerberus Android bot created in June 2019.

The author later started selling the source code of the malware saying that they would only sell it to one person for $25,000. In late April, the price was lowered to $15,000 and it appears that there were still no buyers.

In August, the source code was published free of charge for premium users of one forum. It is likely that the poster did not manage to sell it to anyone.

Threat name	Detection	Regions attacked
Anubis	October 2019	Global

Q3 2020 saw heightened activity of the Android banking Trojan Anubis. It was used in attacks against users in many European countries as well as in Japan, Russia, Turkey, and Australia.

The malware is distributed through Google Play services disguised as legitimate software. It is also spread through phishing pages imitating those of banks. In Russia, there have been detections of phishing pages disguised as those of Russian banks and used for distributing the malware.

Anubis's main functionality includes web fakes, USSD requests, interception and sending of SMS messages, and remote access to target devices. Anubis helps obtain full control over an infected device by automatically disabling Google Protect.

Threat name	Detection	Regions attacked
FlexNet	2014	Russia

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from the C&C server, the application can:

- Change the C&C server address
- Send an SMS message to a specified number
- Send bulk SMS messages with a specified text
- Forward SMS messages to a remote server
- Reply to SMS messages and delete them to conceal the fact from the user
- Run USSD requests
- Schedule commands: configure a command template for new bots for a particular operator and country

In addition, FlexNet had phishing dialogs added to its functionality. They are disguised as popular applications in order to obtain victims' bank card details. The following fake dialog boxes were detected:
AliExpress
Alpha
Avito
Google Play
MyNewAlpha
Telecard
VTB24
Sberbank
Uber

Threats and malware for PC

Threat name	Detection	Regions attacked
UltraRank	March 2020	Global

Group-IB specialists discovered and analyzed the activity of a threat group dubbed UltraRank. Active since at least 2015, the group has used three different JavaScript-sniffer families named FakeLogistics, WebRank, and SnifLite to infect over 600 online stores and steal their customers' bank card data. In addition to online stores, the threat actors targeted at least 13 third-party vendors whose legitimate tools were infected with malware to deliver sniffer code simultaneously to a big number of shops that were the customers of the attacked services. The threat actors also breached the infrastructures of three rival groups and added their sniffer to the rival groups' malicious code.

During the period of its activity, UltraRank has built an autonomous business model with a unique technical and organizational structure. It has also developed its own scheme for monetizing stolen bank card data by selling it through its own card shop called ValidCC. According to the card shop's internal statistics, in a single week in 2019, its owners made between $5,000 and $7,000 a day by selling self-collected bank card data, and another $25,000 to $30,000 was paid to third-party suppliers of stolen payment data.

Threat name	Detection	Regions attacked	Related notifications
Sale of access to corporate networks (vasyldn)	July 2020	Global	CP-2335

In June 2020, Group-IB's monitoring of underground forums revealed a new seller of access to corporate networks, a user with the nickname vasyldn, who offered access to Active Directory–managed corporate networks. The price ranged between $500 and $10,000. At the time of the research, the author had put up for sale 11 instances of access to companies from various industries and countries (Europe, North America, and Australia). The poster's services could be used by threat groups engaged in distributing ransomware in corporate networks.

Threat name	Detection	Regions attacked	Related notifications
Sale of access to corporate networks (drumrlu)	July 2020	Global	CP-2340

This threat actor also started their underground forum activity in June 2020. The "lots" they offer are mostly companies from Europe and the Middle East. In general, the service is very similar to the one described above (by the user vasyldn); the two sellers might be linked. The price for the lots ranges between $1,000 and $3,500.

Threat name	Detection	Regions attacked	Related notifications
BitRAT	June 2020	Global	CP-2408-1945

On June 9, 2020, a user with the nickname UnknownProducts created a thread on Hackforums about the sale of new malware called BitRAT.

According to the description, the malware has the following characteristics:

- Remote desktop (RDP)
- All features of a remote access tool (Hidden VNC/Hidden Desktop/Hidden Browser)
- The source code of the malicious executable is obfuscated
- Keylogger
- Infostealer (supports 35 browsers and over 500 various applications, including email clients and messaging apps)
- Viewing and control of the screen in DualScreen mode
- Grabbing audio from the microphone
- Preview of webcam images/screenshots of infected machines
- Access to Window Manager, Process Manager, Connection Manager, Service Manager, and Registry Manager
- Support for remote shell
- Support for secure connections through cryptographic protocols: TLS up to version 1.3 and Secure Sockets Layer
- Use of a reverse SOCKS4 proxy and a SOCKS5 proxy
- Creation of a client with an ability to connect to a DNS server/IP directly or through Tor Hidden Service
- The Tor client uses a special configuration for bypassing firewalls
- Capability to manage over 10,000 clients with a relatively low CPU load achieved by using FastObjectListView (for devices with Intel Core i7-6650U and 8-GB RAM, it is possible to manage 1,000–5,000 clients with average CPU usage of 1.5%–2%)
- Support for a Monero (XMR) miner
- The Trojan can be used to upload/download/compress files, perform basic actions with files available in Windows, delete files irreversibly, and search file contents
- Full compatibility with Unicode
- Support for a proprietary payment system

The developer mentioned that BitRAT generated an executable file (which is a client written in C/C++), a library (Boost v.1.73), and network libraries (OpenSSL, OpenCV, and LibCurl). For the client to be successfully launched on an infected machine, the libraries are linked statically (they are located inside the body of the executable file). In addition, the poster said that while BitRAT had been successfully tested on devices running Windows 7–10, it could function on all versions of Windows. The author also noted that in order to gain administrator privileges the malware used a UAC exploit, making it possible to obtain admin rights bypassing User Access Control in Windows 10.

The price of one license is $199. The low cost may result in this malware becoming widely distributed.

Threat name	Detection	Regions attacked
zLoader/Silent Night	November 2019	USA Canada Germany UK

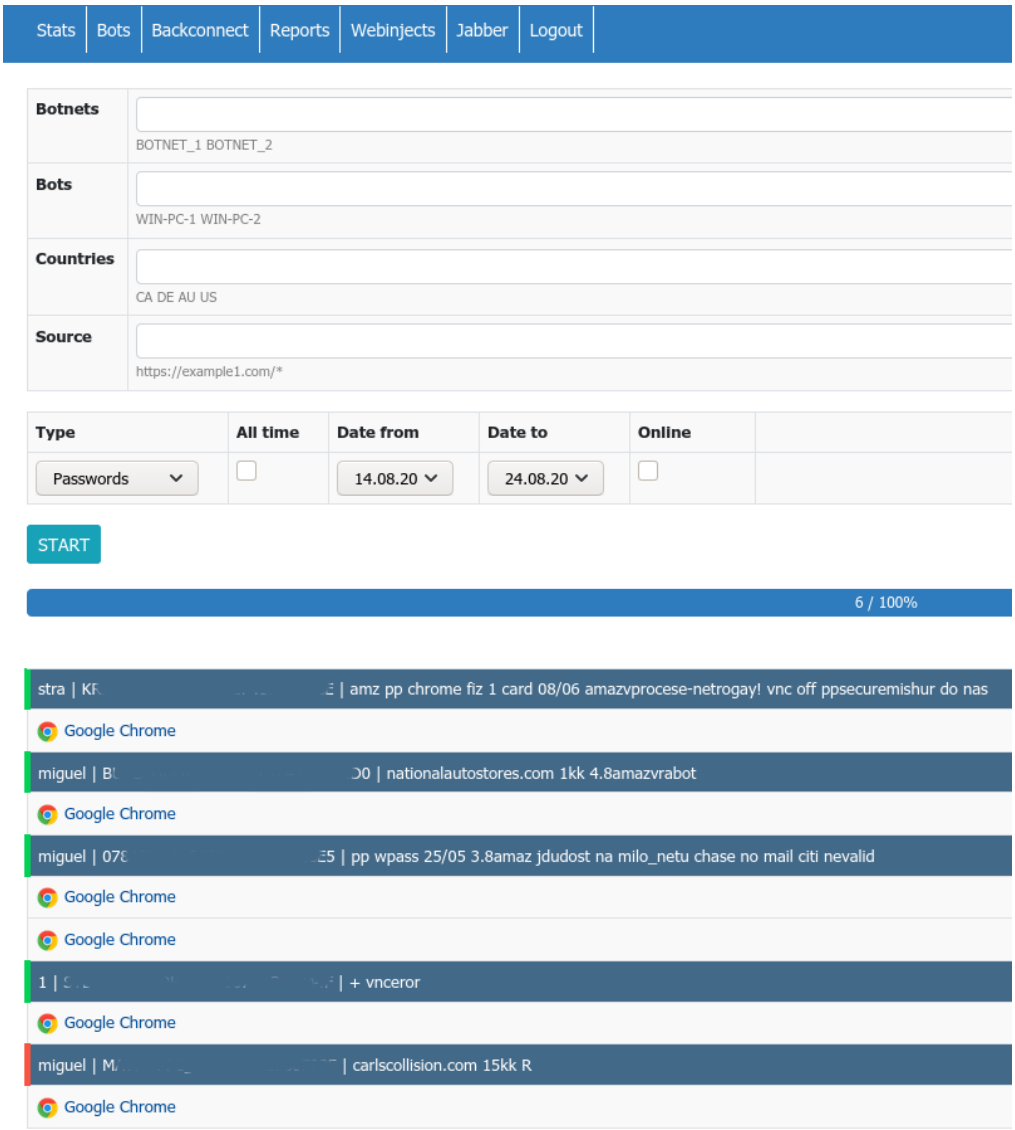
This Trojan was put up for sale in late 2019. In Q1 2020, it started being used in the wild. It is mostly distributed through mailouts with a macro-containing Excel file, which loads zLoader.

Group-IB specialists extracted targets from one of the samples, which revealed the following German banks:

Commerzbank
Sparda-Bank
Comdirect bank AG
Deutsche Bank
Berliner Bank
Norisbank GmbH
Targobank AG

In addition, the malware is known to be attacking banks in the United States, Canada, and the United Kingdom.

Group-IB specialists also analyzed several zLoader panels mostly targeted at users in the US. Below is a screenshot of the panel:



As payload, zLoader then installed Cobalt Strike and Gazavat (PE infector).

Threat name	Detection	Regions attacked
Trickbot	2016	North America Europe Japan Australia

Trickbot is a banking Trojan that uses techniques similar to those of Dyre. It is distributed through email spam. Lately, however, it has often been distributed using Emotet.

In 2020, Trickbot was fitted with new features:

- Bypassing UAC in Windows 10 (it was previously available only for Windows 7) to deliver malware to numerous machines in the network.
- Using Windows 10 ActiveX to execute malicious macros.
- Module for using hacked machines for RDP brute-force attacks.
- In May 2020, Palo Alto Networks discovered that Trickbot's propagation module called nworm had been updated. Infections caused through it leave no artifacts in the victim's domain controller, which disappear after a reboot or shutdown. It is run from RAM. In addition, unlike the previous module (mworm), the new module transfers Trickbot's executable file in encrypted form.

The latest versions of Trickbot attacked the following banks (examples):

Royal Bank of Canada
CITIBANK
CAPITAL ONE
Deutsche Bank
Commonwealth Bank
UniCredit bank
Lloyds Bank
ING bank
Raiffeisen Bank
Canadian Imperial Bank of Commerce
Banco Bilbao Vizcaya Argentaria (BBVA)
Rakuten Inc.
Central 1 Credit Union
ABN AMRO Bank
ANZ Bank
NAB (National Australia Bank)
Credit Agricole
Westpac
POSTE ITALIANE S.P.A.
Intesa Sanpaolo
ICCREA
BNL Banca Nazionale del Lavoro
BNP Paribas
Santander
Danske Bank
SpareBank 1
Piraeus Bank

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Australia, Italy

In May 2020, Group-IB specialists analyzed a new version of the banking Trojan Gozi/ISFB – Gozi v3. It has the same functionality as that of Gozi 2.X versions. The difference is in the modular architecture. The main features include:

- MITB (Man-In-The-Browser) attacks using web injects
- Theft of user accounts from infected devices
- Execution of CMD commands
- Download of files to the infected device and their execution
- Extension of functionality through the download of additional modules from the C&C server
- Video recording

Q3 2020 saw the discovery of attacks involving Gozi v3 and Gozi v2.

Australian and Italian banks are among the targets.

Australia:
ANZ
Bankwest
Bendigobank
Commonwealth bank
National Australian Bank
Westpac

Italy:
cedacri.it
bnl.it
cdp.it
inbank.it
mps.it
relaxbanking.it
unicredit.it
nexi.it
bancobpm.it
tecmarket.it
bancobpm.it
abi.it
bancaubae.it
bpergroup.net
cariparma.it
bnl.it
intesasanpaolo.com
poste.it

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	USA, Canada

IcedID was first detected in late 2017. The malware can be used to steal financial information and launch targeted attacks. IcedID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches IcedID.

IcedID has a modular architecture and many features of Zeus, including web injects, data theft, and the ability to inject code into other processes. One of the bot's specific characteristics is its ability to deploy a proxy server on an infected machine and redirect all Internet traffic using that server.

In addition to banks, IcedID currently attacks e-commerce businesses. In either case, the criminals' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

In May 2020, Group-IB specialists analyzed a new version of IcedID (21st one), in which configuration files were hidden in PNG images. In an earlier version (e.g., 12), the PNG file only contained the main module.

In mid-2020, it was discovered that the Valak loader started to be used to distribute IcedID.

The detected IcedID samples target banks in the US, Canada, and the UK as well as e-commerce vendors.

Known targets:

Amazon.com
American Express
AT&T
Bank of America
Capital One
Chase
CIBC
Comercia (comerica.com)
Dell
Discover
Dollar Bank
eBay
Erie Bank
E-Trade
Frost Bank
Halifax UK
Hancock Bank
Huntington Bank
J.P. Morgan
Lloyds Bank
M&T bank
Centennial Bank
PNC
RBC
Charles Schwab
SunTrust Bank
Synovus
T-Mobile
Union Bank (unionbank.com)
USAA
US Bank
Verizon Wireless
Wells Fargo

Threat name	Detection	Regions attacked
RTM	2015	Russia, Belarus, Kazakhstan, Ukraine, Azerbaijan

RTM is written in Delphi and is a modular Trojan. Judging by its functionality, it targets remote banking services and payment systems. Its latest tracked sample searched for the following remote banking services on infected machines: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, and VTB24.

The RTM group has a main panel and a separate proxy panel showing banks the group targets specifically: all requests are sent to phishing servers where the traffic is proxied.

Since early 2019, mass emails that distribute the RTM Trojan have continued to be actively sent out. We detect such emails almost every day. The recipients are Russian-speaking legal entities.

In late 2019, it was established that RTM was involved in attacks on legal entities in Belarus. The remote banking systems of the following banks were targeted: Belarusbank, BPS-Sberbank, BelVEB, BSB Bank, Belgazprombank, Alfa-Bank, Belinvestbank, Idea Bank, Paritetbank, MTBank, StatusBank, and Belagroprombank.

The malware's main targets are small and medium-sized enterprises. However, computers in the infrastructures of large businesses and government agencies are also targeted.

Threat name	Detection	Regions attacked
Danabot	2018	Australia, Germany, Polands

The modular banking Trojan Danabot was first detected in the spring of 2018. It uses web injects and intercepts victims' data. It has VNC, Sniffer, Stealer, TOR, and RDPWrap modules.

New features were later added to it, namely, several layers of encryption for transferring data to the C&C server and a new loader component with an ability to load plugins along with the main module, which makes it an even greater threat.

As in the previous quarter, in Q3 2020 we detected Danabot samples that targeted banks in Australia, Germany, and Poland.

Examples of banks attacked:
Australia and New Zealand Banking Group
Westpac
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Commonwealth Bank of Australia
National Australia Bank
Comdirect
Berliner bank
Norisbank
Targobank
Citibank (PL)
Ideabank (PL)
Bosbank24
Bnpparibas (PL)
Toyotabank (PL)
Plusbank24
Nestbank

Threat name	Detection	Regions attacked
Ramnit	2010	Japan, Italy

The banking Trojan Ramnit was discovered in 2010. In 2015, the Ramnit botnet was taken down by a joint international operation coordinated by Europol. The Trojan's activity, however, did not stop and it continued to be used to compromise bank cards in North America and Europe up until the beginning of 2018. It was followed by a lull, but in late 2018 Ramnit resumed its activity. The threat actors focused on attacks against Japan and the United States, occasionally targeting European banks.

In Q3 2020, Ramnit was quite active and attacked banks in Japan and Italy.

Threat name	Detection	Regions attacked
Qbot	2009	USA, Canada

Qbot (QakBot) emerged in 2009 and has since been regularly improved. Qbot is a modular multithread Trojan that can steal banking data, digital certificates, authentication tokens, and cookies as well as function as a keylogger, backdoor, and SOCKS proxy; it also has antivirus evasion features. Qbot is designed to target businesses and steal money from bank accounts. The Trojan is distributed as a worm by self-replicating through shared drives and removable media.

The configuration file of the latest version of Qbot contains the following targets:

Chase
BB&T
Citizensbank
Capitalone
Firstcitizensonline
Suntrust
Wellsfargo
Frostbank
Scotiabank
Usbank
Bank of America
Bank of Montreal
Royal Bank of Canada
Citibank
The PNC Financial Services Group
TDBank
Amegybank
National Bank of Arizona
Vectrabank

Threat name	Detection	Regions attacked
Grandoreiro	2017	Latin America, Europe

The malware has been known since 2017. Since April 2020, there has been a rise in its distribution against the backdrop of the COVID-19 pandemic.

Group-IB specialists obtained a list of targets from a sample of this malware and established that banks in Brazil, Spain, the UK, Peru, and Germany were among the targets.

Below is the list of targets from the configuration file analyzed by Group-IB specialists:

Banco do Brasil
Cecabank (ES)
Natwest (UK)
Santander (UK)
HSBC (UK)
Barclays
BancoEstado
Falabella
Santander
Scotiabank
Liberbank
BBVA
BANKIA
lacaixa
Sabadell
BANKINTER
labooral
cajamar
Openbank
ING

Pichincha (PE)
CaixaGeral
Mediolanum
Unicaja
Cecabank
BarclaysES
BNPParibas
Cajasur
CitiBusiness
Commerzbank
Deutsche
EVOBanco
HSBCEspaca
MicroBank
MiBanco
novobancopt
santapt
millenniumbcppt
Caixadirectapt
EuroBicpt
BancoBAIEUROPA
bancocarregosa
BancoCTT
BancoInvest
BancoSabadellPortugal
BankinterPT
BisonBank
BancoBNIEuropa
BancodePortugal
Haitong
HuamboPT
OpenbankPT
BFFPortogallo
Rankiapt
cecabank
CTIVOBANK
CaixaGeral
BBVA
LACAIXA
STDAESPANHA
BANKINTER
laboral
BBANKIA
cajamar
Liberbank
Openbank
ING
Pichincha
ibercaja
Mediolanum
Unicaja
TRIODOS

bancobcr
BarclaysES
BNPParibas
CAIXAGUISSONA
Cajasur
CitiBusiness
Commerzbank
Deutsche
EVOBanco
HSBCEspaca
MicroBank
MiBanco
ACTIVOBANKPT
novobancopt
MONTEPIOpt
santapt
millenniumbcppt
Caixadirectapt
EuroBicpt
SBPI
ABANCAPT
ATLANTICOEuropa
BancoBAIEUROPA
bancocarregosa
BancoCTT
BancoInvest
BancoSabadellPortugal

Threat name	Detection	Regions attacked
Javali	2017	Latin America

This banking Trojan emerged in 2017 as well. It targets banking customers and cryptocurrency owners.

Below is a list of targets from a configuration file analyzed by Group-IB specialists:

Banco do Brasil
Banco Bradesco
Bradesco
Bradesco JuJu
Santander
Banco Sicredi
Mercantil
Caixa Economica
Banco Sicoob
Unicred Portal
Internet Banking BNB
Banco BNB
Banco Inter
Banco Intermedium
Banco MUFG Brasil S.A.

Banestes
Bancos Geral
Mercado Pago
Banco Safra
SafraNet
BANCO PAULISTA
Uniprime
Bem vindo ao seu BMG
BMG
Portal - Banco Votorantim
Votorantim
Pine Online
NBC BANK
Tribanco
Banco Alfa
Banco Indusval
Portal Internet Banrisul
Banrisul
Banco Original
Acesse sua conta Celcoin
Celcoin
Nubank
BRB Banknet
Banese
Banco Topazio
Banco Industrial
Daycoval
Viacredi

Threat name	Detection	Regions attacked
Melcoz	2018	Latin America

Melcoz has been active since 2018. It initially attacked users in Mexico, Spain, and Chile; at the moment, it mainly attacks targets in Brazil.

Below is a list of targets from a configuration file analyzed by Group-IB specialists:

santander.com.br
safra.com.br
santanderempresarial.com.br
sicredi.com.br
unicred.com.br
bb.com.br
bancobrasil.com.br
INTERNETBANKING.CAIXA.GOV.BR
bradesco.com.br
nel.bnb.gov.br
itau.com.br

Threat name	Detection	Regions attacked
Guildma (Astaroth)	2017	Latin America, Spain, Portugal

The Trojan was discovered in 2017. In the second half of 2019, it started attacking users mostly in Brazil. During that period, it was distributed primarily through COVID-19–related email spam. At the moment, it also attacks users in Spain, and Portugal.

Attacks on ATMs and POS terminals

Threat name	Detection	Regions attacked	Related notifications
Sale of the source code of ATM malware	September 2020	Global	CP-2409-1550

In late September, a threat actor with the nickname kirilnefimov made a post about selling the source code of ATM malware. According to the description, the malware targets ATMs of the following manufacturers:

- NCR
- Wincor
- Diebold Nixdorf

At the moment, it is not known what specific ATM models are targeted by this malware. The set of features is not known either, but we assume that that main goal is jackpotting.

The seller asks $10,000 for the source code.

There is currently no additional information about the malware, but there are suggestions that the seller does not deliver on their promises.

Ransomware

Threat name	Detection	Regions attacked
Maze	May 2019	Global

This threat group has lately attacked the following companies:
Toledo Public Schools
Rx Technology
Ghantoo Group
Guillevin International Co.
Clayton Industries
Clark County School District
JX Enterprises, Inc
Groupe Interway
Artech Information Systems LLC
BRUSCHI S.P.A.
Triad Mechanical Contractors
Lally Ford
Capital Lumber Company
Fondazione Arena di Verona
BIRAGHI S.p.A.
KUHNLE-TOURS GmbH
Express Manufacturing, Inc.
BlueLinx Holdings
Spectrum Associates, Inc.
Hedinger & Lawless, LLC
Conklin Office Furniture
East Bay Restaurant Supply
Sussek Machine Company
Indian River Transport Ltd.
Proforce Equipment, Inc.
Texfyt Indústria
Karmsund Maritime Group AS

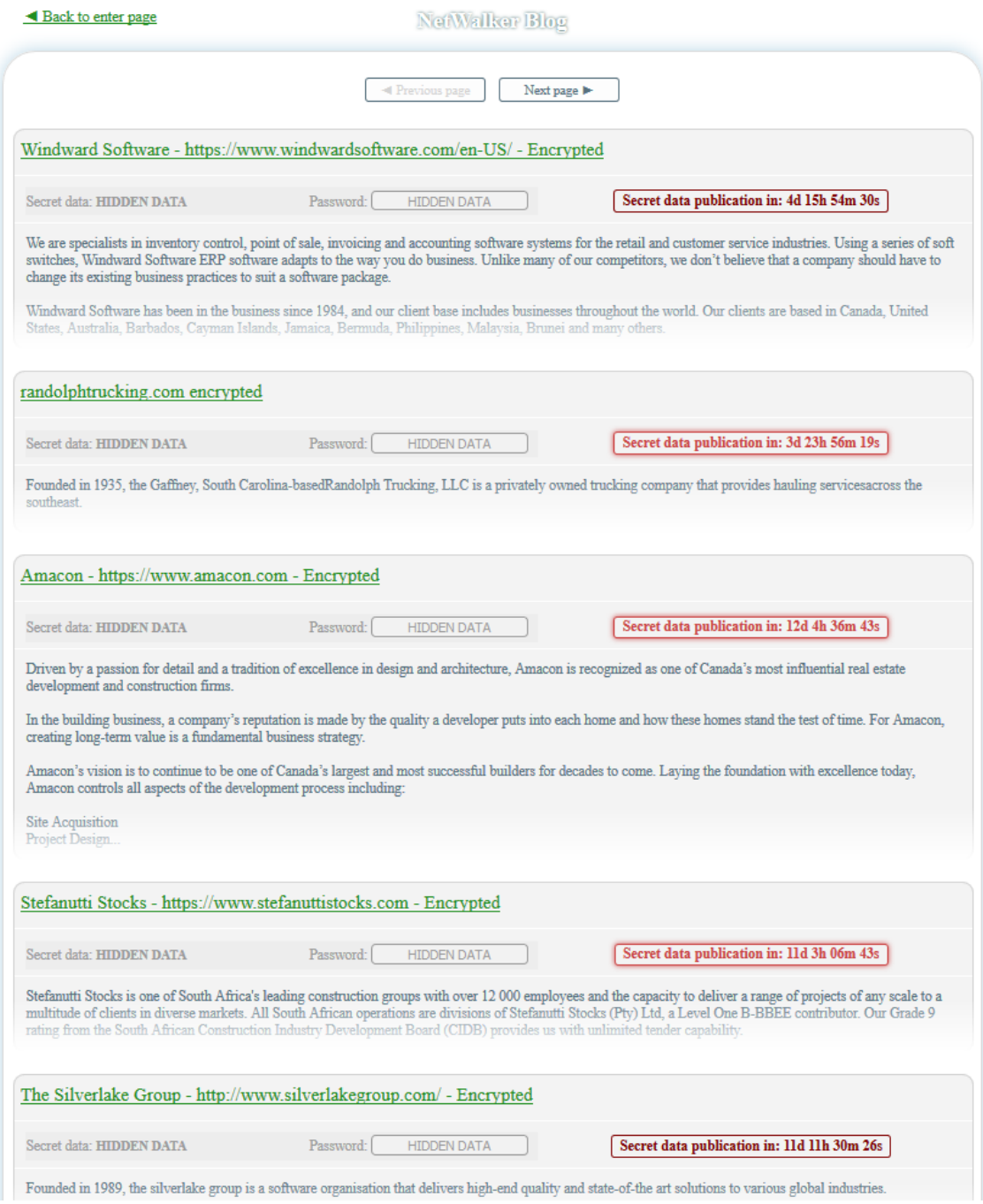
The targets include European, Latin American, and US-based companies.

Threat name	Detection	Regions attacked	Related notifications
Netwalker	September 2019	Global	CP-2325

The threat actors first announce their intent to publish stolen data specifying the time when they are planning to do so (usually 7-12 days in advance), then wait for the ransom to be paid within that period and if that does not happen, the group publishes all stolen data. There were cases, however, when all mentions of a particular company were deleted from the website (the latest example is Windward Software).

Companies compromised:

Heatherwick
Horizon Gulf Electromechanical Services L.L.C
Spectra Aluminum Products
record.fr
SELDENS (www.seldens.com)
redplanethotels.com (Asia's largest and fastest-growing hotel company focused)
GAM - gamrentals.com
randolphtrucking.com
Amacon - amacon.com
Stefanutti Stocks - stefanuttistocks
The Silverlake Group - silverlakegroup.com
CubeLogic - cubelogic.com
mainstreamrp.com
CRE Credit Services encrypted
Migraciones Argentina Encrypted
Tandem Corp - tandemcorp.com



Threat name	Detection	Regions attacked
LockBit	January 2020	Global

The partner program for the LockBit ransomware appeared on underground forums in January 2020.

This ransomware has lately been used in attacks against the following companies:

Skyline Displays (skyline.com)
Yaskawa Electric Corporation
Overseas Express

LOCKBIT

LEAKED DATA

Skyline Displays (skyline.com) PUBLISHED FILES Secret data link: open links Password:

Skyline Displays, Inc. offers marketing communications services. The company provides displays, exhibits designing and manufacturing services. Additionally Employees: 1,200 Revenue: $231 Million Data includes: -Credit cards (full number, exp date, holder name/surname, cvv2) -Passport us citizens scans, ssn scans, driver licenses scans -Bank and accountant data -Payroll

MORE →

Yaskawa Electric Corporation PUBLISHED FILES Secret data link: open links Password: tQaqi058mDbD...

The Yaskawa Electric Corporation is a Japanese manufacturer of servos, motion controllers, AC motor drives, switches and industrial robots. The company was founded in 1915, and its head office is located in Kitakyushu, Fukuoka Prefecture. Yaskawa applied for a trademark on the term "Mechatronics" in 1969, it was approved in 1972.

MORE →

Overseas Express PUBLISHED FILES Secret data link: open links Password: LockBit!8Sj1...

Overseas Express (overseas.hr) Shipping Company. FULL CUSTOMER DATA LEAK . 5.8 million records including: Names, Address, Phone No., Emails, Tracking numbers and more. + Additional internal PDFs and DOC files.

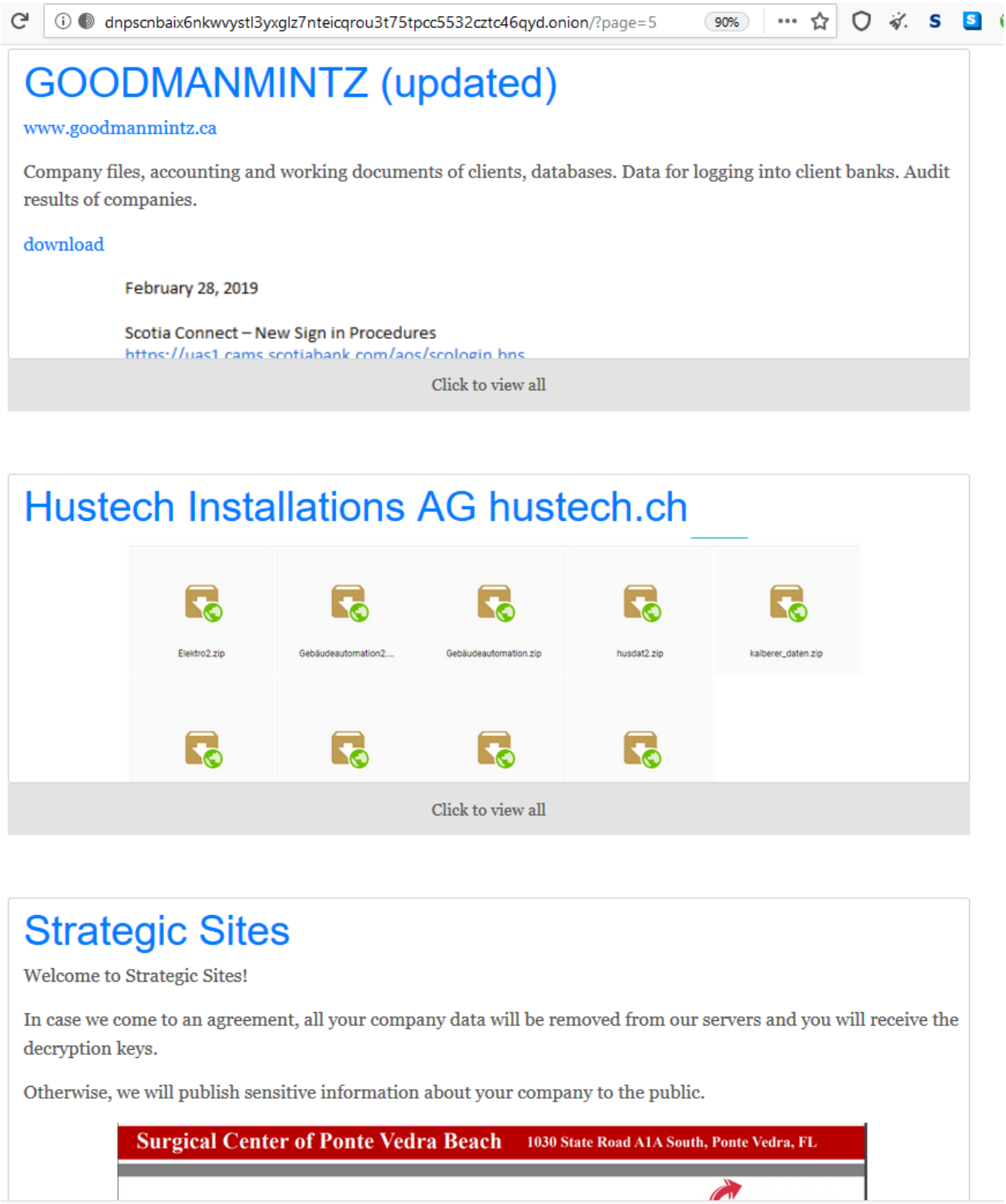
Threat name	Detection	Regions attacked
WastedLocker	May 2020	USA

In July 2020, Garmin, a major manufacturer of smart watches and navigation equipment, experienced an outage of its cloud service. Customers could not upload data from their devices for several days. The company said it had suffered a cyberattack. It was established that the threat actors had used the WastedLocker ransomware.

Garmin's operations were recovered in a few days. The company did not make official announcements, but with all the circumstances taken into account, the company is thought to have paid hackers $10 million in ransom. The payment was reportedly made through a ransomware negotiation company.

Threat name	Detection	Regions attacked
REvil (Sodinokibi)	2019	Global

The blog of this threat group is made up of two parts: the first part is used to publish partial archives with compromised data of victim companies or to provide descriptions of full data.



The second part is an auction where full archives are sold.

Happy Blog Auction (new) Blog search Search

australian company ARAFMI

we presents you some files of australian company https://growjo.com/company/ARAFMI
https://www.arafmi.com.au/
here some screenshots of files https://anonfiles.com/x8k7kcK8oa/screen_rar

Minimum deposit:	$500	Top bet:	--
Start price:	$5,000	Blitz price:	$60,000

Not paid The secret data of the lot has been published :)

Grubman pack - Jessica Simpson

All Jessica Simpson legal documents from Grubman office.

Minimum deposit:	$60,000	Top bet:	--
Start price:	$600,000	Blitz price:	$1,500,000

Opened Time left: 7 days, 19 hours, 35 minutes and 14 seconds

Grubman pack - Gallant

All Gallant legal documents from Grubman office.

Minimum deposit:	$60,000	Top bet:	--
Start price:	$600,000	Blitz price:	$1,500,000

Opened Time left: 7 days, 19 hours, 35 minutes and 07 seconds

The number of compromised companies is in the dozens. Some of them are listed below:

Telecom Argentina
Amicorp Group (www.amicorp.com)
DYNEA.NET
eurecat.com
4datanet.com
Sampoerna Agro (www.sampoernaagro.com)
greatnortherncorp.com
taylorfarms.com
DXP Enterprises, Inc.
Meinhardt Group
n&k technology inc software
aaaambulance.net
Australian company ARAFMI

In addition, in September 2020 it came to light that the group had attacked BancoEstado (Chile). The data has not yet appeared on the attackers' website.

Threat name	Detection	Regions attacked
Clop Ransomware	May 2020	Germany

In their blog, the threat group mentioned attacks against the following companies:

Prettl group (PRETTL.COM)
NETZSCH Holding (NETZSCH.COM)
ProMinent (PROMINENT.COM)
HÖDLMAYR INTERNATIONAL AG (HOEDLMAYR.COM)
Indianbulls (INDIABULLS.COM)

Threat name	Detection	Regions attacked
Nefilim	March 2020	Global

This threat group continued to publish new archives affecting companies that had been attacked earlier (Cosan, Asteris SA, MAS Holding, Stadler Rail, Toll Group).

New victims include Orange, Indoco Remedies Ltd. Treaser, Simon Holdings Plc, The Dussmann Group, SPIE group, Burger king Jamaica, Panpharma Group, and S.L. Fusco.

RECENT POSTS

The Dussmann Group. Part 2. September 16, 2020

Toll Group. Part 5. September 13, 2020

S.L. Fusco. Part 1 September 9, 2020

Panpharma Group. Part 1. September 9, 2020

Burger king Jamaica. Part 1. September 9, 2020

Toll Group. Part 4. August 20, 2020

Arteris SA. Part 6. August 20, 2020

RECENT POSTS

SPIE group. Part 1. August 9, 2020

The Dussmann Group. Part 1. July 27, 2020

Orange SA. Part 2. July 27, 2020

Stadler Rail. Part 4. July 27, 2020

Simon Holdings Plc. Part 1. July 15, 2020

Indoco Remedies Ltd. Teaser. July 15, 2020

Orange S.A. Part 1. July 15, 2020

MAS Holdings. Part 6 July 11, 2020

Arteris SA. Part 5. July 9, 2020

Cosan. Part 7. July 5, 2020

Threat name	Detection	Regions attacked
DoppelPaymer	June 2019	Global

DoppelPaymer operators were also very active and published data on the following companies in their blog:

Latest proofs:

Optima Italia S.p.A.
Newcastle University
[Proof] TFI Internatioal (Canpar)
[Proof] SASEGUR - Seguridad y Sistemas
[Proof] 株式会社クワタ

Latest leaks:

Canpar Express
Digital Systems Engineering (DSE)
NIF Nif Group, Inc.
Salvador Escoda SA
Royal Military College of Canada

Below you can find private data of the companies which were hacked by DoppelPaymer. This companies decided to keep the leakage secret. And now their time to pay is over.

Canpar Express
URL: http://www.canpar.com/
Read more
Views: 7634 | Published: 2020-08-24 20:42:16 | Updated: 2020-09-15 06:48:45

Optima Italia S.p.A.
URL: http://www.optimaitalia.com/
Read more
Views: 1562 | Published: 2020-09-14 07:55:15 | Updated: 2020-09-14 07:55:15

Newcastle University
URL: https://www.ncl.ac.uk/
Read more
Views: 3758 | Published: 2020-09-07 15:01:38 | Updated: 2020-09-07 15:01:38

Digital Systems Engineering (DSE)
URL: https://www.digitalsys.com/
Read more
Views: 4623 | Published: 2020-09-02 08:40:16 | Updated: 2020-09-02 13:48:07

NIF Nif Group, Inc.
URL: http://www.nifgroup.com/
Read more
Views: 4443 | Published: 2020-08-30 19:06:14 | Updated: 2020-09-02 13:47:43

Salvador Escoda SA
URL: https://www.salvadorescoda.com/

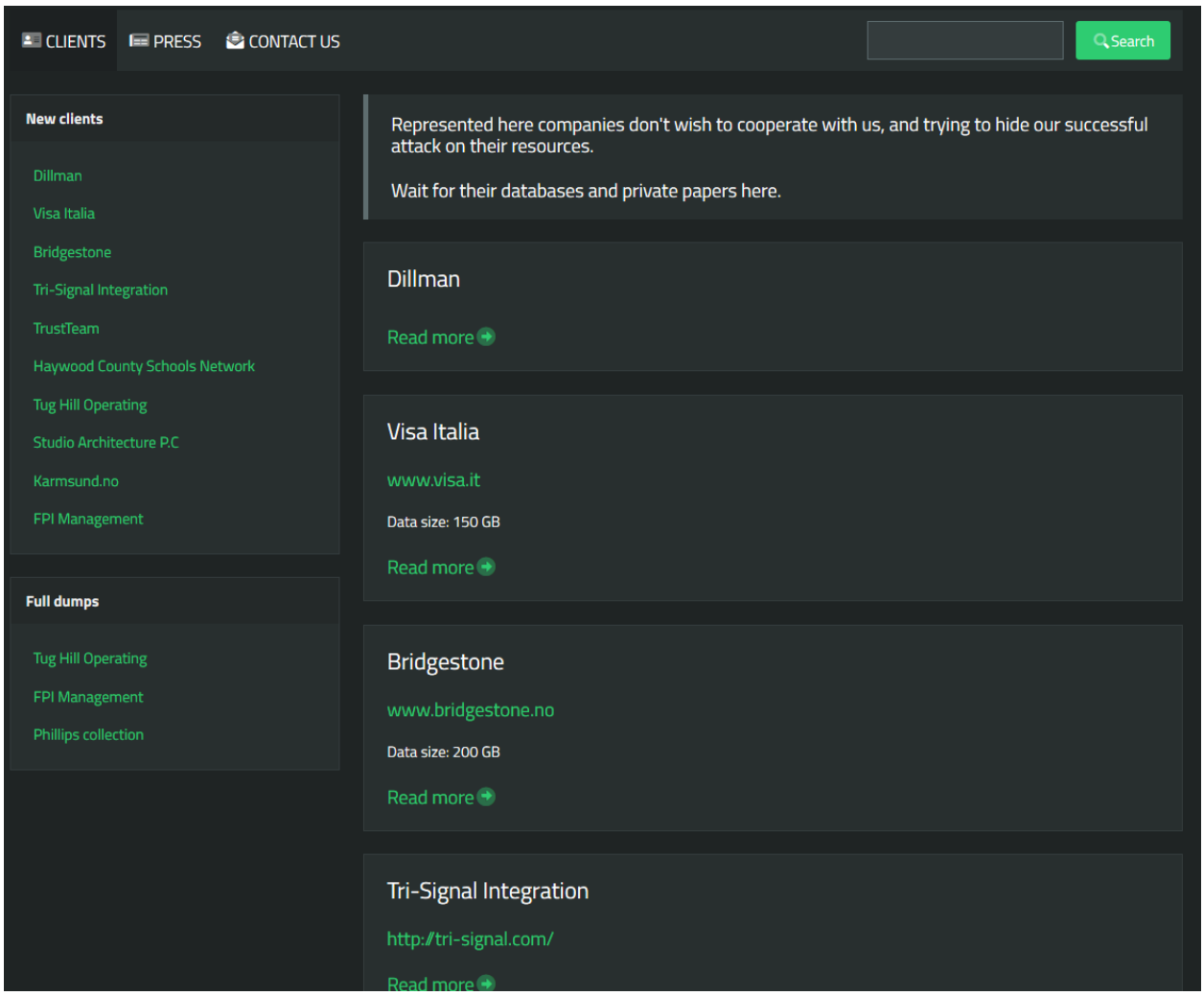
Canpar Express
Optima Italia S.p.A.
Newcastle University
Digital Systems Engineering (DSE)
NIF Nif Group, Inc.
Salvador Escoda SA
TFI Internatioal (Canpar)
SASEGUR - Seguridad y Sistemas
株式会社クワタ (http://kuwata-glass.co.jp/)
VUTEQ CORPORATION
DAISHO Co,.Ltd.
Asunaro Aoki Construction Co.,Ltd.
Royal Military College of Canada
KCG, Inc.
Salem Media Group, Inc.
DiVal Safety Equipment, Inc.
The Old Spaghetti Factory (OSF)

Bell Mechanical Services, LLC
Amphastar Pharmaceuticals, Inc
Coaching Headset Systems
Complite Cash
Office of Joe G. Tedder: Tax Collector, Polk County, Florida
Thomas Motors Inc / Advantagenissan
Transport Express Minimax Inc
IBMC College
City of Knoxville TN

Threat name	Detection	Regions attacked
SunCrypt	October 2019	Global

This ransomware was used in attacks against the following companies:

Dillman
Visa Italia
Bridgestone
Tri-Signal Integration
TrustTeam
Haywood County Schools Network
Tug Hill Operating
Studio Architecture P.C
Karmsund.no
FPI Management
University Hospital New Jersey
Trisignal



Threat name	Detection	Regions attacked	Related notifications
Avaddon	June 2020	Global	CP-2354

In June, a new partner program called Avaddon appeared on underground forums. Its author is a Russian-speaking threat actor and using the malware is not permitted in the Commonwealth of Independent States (CIS).

Attacks involving this ransomware in the wild were already detected in June 2020. A blog associated with Avaddon currently has data on the following victims:

Golden Aluminum
Sky Leasing, LLC

AVADDON RANSOMWARE

Main | Full dump | Contact Us

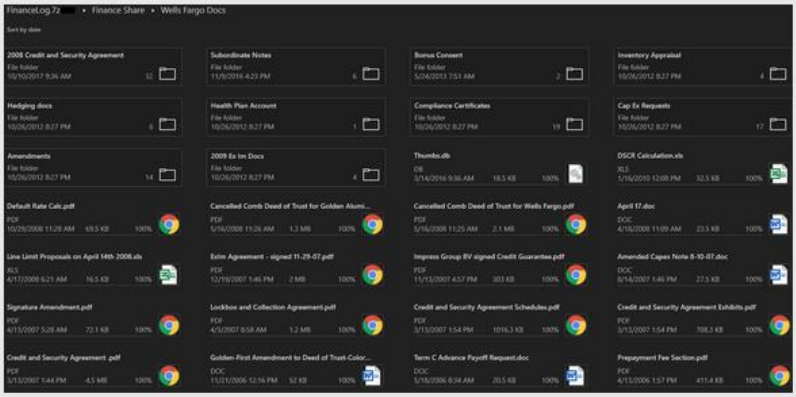
Golden Aluminum -- Leak 5 %

The company probably does not understand the whole seriousness of the situation, if you do not contact us within 48 hours, your entire database will be leaked in the amount of more than 50 GB, and this is customer data, employee data and other very important documents.

Below you can see the 5% leak at the bottom of the article.

https://goldenaluminum.com/

Email: info@goldenaluminum.com
Phone: (303) 718-8276
Phone 2: (800) 838-1004
Address: 1405 14th St, Fort Lupton, Colorado, 80621, United States



Read more...

Sky Leasing, LLC---Leak 5 %

Sky Leasing, LLC

The company probably does not understand the whole seriousness of the situation, if you do not contact us within 48 hours, your entire database will be leaked in the amount of more than 100 GB, and this is customer data, employee data, drawings and other very important

Golden Aluminum -- Leak 5 %

Sky Leasing, LLC---Leak 5 %

State-sponsored APTs

APT name	Regions attacked	Operation start
APT28	USA	2019

In August 2020, the FBI and the NSA released a report on the Drovorub malware, designed for Linux and attributed to APT28. Drovorub comprises four components:

- Drovorub-client
- Drovorub-kernel module
- Drovorub-agent
- Drovorub-server

Once installed, the Drovorub implant provides the capability for direct communications with actor-controlled C&C infrastructure, file download and upload capabilities, execution of arbitrary commands as "root," and port forwarding of network traffic to other hosts on the network. The rootkit uses a variety of means to hide itself and the implant on infected devices and establishes persistence.

Communication between the components is conducted via JSON over WebSockets. The Drovorub-agent, Drovorub-client, and Drovorub-server require configuration files and an RSA public key (for the Drovorub-agent and Drovorub-client) or private key (for the Drovorub-server) for communication.

The Drovorub-server, installed on actor-controlled infrastructure, enables C&C for the Drovorub-client and Drovorub-agent. The Drovorub-client component is installed on target endpoints by the actor, receives commands from its remote Drovorub-server, and offers file transfer to/from the victim, port forwarding, and a remote shell capability. The initial configuration for the Drovorub-client is embedded within its executable. The Drovorub-kernel module institutes: process hiding, file hiding, socket hiding, and netfilter hiding. The Drovorub-agent receives commands from its configured Drovorub-server and includes much of the same functionality as the Drovorub-client, except for the remote shell capability.

In September 2020, a new APT28 campaign, which started on August 5, was discovered. The campaign involved October 2020 NATO training materials as a lure. The attacks targeted a government body in Azerbaijan, but other countries involved in NATO exercises may have also been targeted.

A file called “Course 5 – 16 October 2020[.]zipx” was discovered on VirusTotal (VT). Renaming the file as a JPG will show the logo of the Supreme Headquarters Allied Powers Europe (SHAPE), which is the NATO’s Allied Command Operations (ACO) located in Europe.

The file drops a Zebrocy malware executable and a corrupted Excel file, whose aim is to make the victim execute the malware. The attackers used a Delphi version of the Zebrocy malware.

Once executed, the malware creates a scheduled task that regularly tries to send stolen data to a remote domain. If no interesting information is sent to the C&C server, the server breaks its connection with the infected host.

Researchers note that the new APT28 campaign is very similar to the ReconHellcat campaign, which was discovered last month (it will be described later in this report). Both the compressed Zebrocy malware and the lure for dropping the BlackWater backdoor were uploaded on August 5 by the same user in Azerbaijan (highly likely by the same organization); both attacks occurred in the same timeframe.

APT28 is a Russian-speaking cybercriminal group active since 2004. Most of the group’s attacks have targeted political and military organizations, and, to a lesser extent, media outlets and sports organizations.

APT name	Regions attacked	Operation start

RedDelta	Vatican, China, Italy, India, Indonesia, Myanmar, Ethiopia, Australia	February 2020

In July 2020, information about another Chinese APT group called RedDelta was discovered. For their attacks, the threat actors used phishing emails and modified versions of PlugX, Poison Ivy, and Cobalt Strike.

Throughout 2020, the group carried out the following attacks:

- May–July. An attack against the Catholic Diocese of Hong Kong. The attack involved a ZIP archive with an executable within, which was used to load a malicious DLL through DLL side-loading. The decoy document purported to be an official Vatican letter addressed to the head of the Hong Kong Study Mission to China.
- May-July. C&C infrastructure that communicated with Vatican hosts was discovered.
- June. An attack against the Pontifical Institute for Foreign Missions, Italy took place.

Analysis of the attacker infrastructure revealed several more possible victims:

- February–June. An attack against the Sardar Vallabhbhai Patel National Police Academy, India.
- May–July. An attack against the Ministry of Home Affairs of Indonesia.
- June–July. An attack against the Airports Authority of India.
- May–July. Attacks against unidentified victims in Myanmar, Hong Kong, Ethiopia, and Australia.

Other decoy documents were also detected (titled “About China’s plan for Hong Kong security law.zip” and “QUM, IL VATICANO DELL’ISLAM.doc”), which load the same customized PlugX variant.

Currently, there is a suggestion that the Mustang Panda threat group is behind RedDelta’s activity. Similarities in malware configurations and C&C overlap may indicate that the two teams closely cooperate and use common resources, but perhaps take slightly different actions to achieve their goals.

RedDelta is a Chinese threat group focused on cyber espionage and active since at least February 2020. Their target sectors include law enforcement agencies, religious organizations, and government bodies. Their attacks have targeted the Vatican, China, Italy, India, Indonesia, Myanmar, Ethiopia, and Australia.

APT name	Regions attacked	Operation start
Operation PowerFall (potentially by DarkHotel)	South Korea	May 2020

August 2020 saw the publication of information about operation PowerFall targeted at a South Korean organization. The group responsible for the attack has not yet been identified, but security researchers believe the DarkHotel group could be behind it.

In their campaign, the threat actors used two zero-day vulnerabilities. The first one is CVE-2020-1380 in Internet Explorer, which has to do with incorrect use of dynamic memory and allows attackers to execute arbitrary code. The second vulnerability is CVE-2020-0986 in Windows; its exploitation makes it possible to elevate privileges and perform unauthorized actions.

As a result, the threat actors compromised several machines of employees and subsequently penetrated into the internal network of the targeted organization.

DarkHotel is a cybercriminal group active since 2007 and believed to be based in North Korea. The group’s primary targets are luxury hotel guests and political organizations mostly in North-East Asia. The aim of the group’s attacks is to collect confidential information and carry out cyber espionage.

APT name	Regions attacked	Operation start
Turla	Europe	June 2020

June 2020 saw an attack targeting an organization in the foreign affairs sector in the European Union. The attack is attributed to the Turla threat group; it involved a previously unknown program dubbed NewPass, which includes three components:

- Dropper, which deploys a backdoor and its configuration file.
- Loader. To begin, it checks the presence of the associated configuration file; if it does not exist, the backdoor terminates its execution. If the file is found, the malware starts to decode and read the current configuration. The decoding results in the obtainment of parameters used to load the final payload — the agent. The configuration file contains the following parameters: C&C address; agentID used during communication with the C&C as the identifier of an infected machine; and malware version. The configuration also embeds a specific structure for persistence mechanisms. The malware is able to create services or tasks and add registry keys to achieve persistence.
- Agent, which is the final module of the malware. It is used for exfiltrating information from an infected machine and sending it to the C&C server. The agent uses a set of keywords to separate data within a POST request. All the values embedded into the request are encrypted, probably using one of the keys embedded into the configuration file. The algorithm used during the encryption phase is most likely a custom one.

Turla is a Russian-speaking cybercriminal group believed to have been active since 2007. The main goal of Turla's attacks is to steal information from diplomatic, government, military, educational, research, and pharmaceutical organizations.

APT name	Regions attacked	Operation start
Attacks involving WellMess, WellMail, and SoreFang malware	USA, Canada, UK	2020

July 2020 saw the publication of information about attacks targeting organizations involved in COVID-19 vaccine development in the United States, Canada, and the United Kingdom. The attacks involved WellMess, WellMail, and SoreFang malware.

The group conducted basic vulnerability scanning against specific external IP addresses owned by the organizations. The group then deployed public exploits against the vulnerable services identified. In particular, vulnerabilities CVE-2019-19781, CVE-2019-11510, CVE-2018-13379, and CVE-2019-9670 were exploited.

Upon gaining access to a target system, the attackers deployed multiple malicious programs:

- WellMess, which is lightweight malware written in Golang or .NET. It has been used since at least 2018 and is designed to execute arbitrary shell commands and upload and download files. The malware supports HTTP, TLS, and DNS communication methods.
- WellMail, which is a lightweight tool written in Golang and designed to run commands or scripts with the results being sent to a hardcoded C&C server.
- SoreFang malware, which is used to exfiltrate victim information and download second-stage malware.

Researchers link these attacks to APT29 but do not provide substantiation to confirm that link. Moreover, these malicious programs had earlier been used by the DarkHotel group and some of the indicators of compromise provided by the researchers have already featured in the descriptions of DarkHotel attacks against Chinese organizations.

APT name	Regions attacked	Operation start
OceanLotus	Vietnam	July 2020

Since July 2020, our system for detecting malicious infrastructures has detected five hosts that have the Cobalt Strike post-exploitation framework deployed. We believe that these hosts are controlled by the OceanLotus group. Researchers at Group-IB have also obtained payload from these servers and additionally confirmed that the hosts belong to the group. In addition, we have detected domains that can be attributed to OceanLotus with medium confidence. A file called "CV_Enginneer_Version_CH.zip," which is an SFX archive, is linked to one of these domains. After it is unpacked, a file called "CV_Enginneer_CH.doc~.exe" is launched and connection to beautifull-font.salebusinesend[.]com is established.

The executable also creates the following files in the \Temp\RarSFX0 directory:

- SoftwareUpdateFiles.dll
- SoftwareUpdateFiles.locale
- SoftwareUpdateFilesLocalized.dll
- WindowsUpdateAssistant.exe

Some of them are legitimate files by Apple with a valid digital signature except for "SoftwareUpdateFilesLocalized.dll," which is a malicious library that uses the Dll side-loading technique. The group used an identical method of loading executable files in June 2020.

OceanLotus, also known as APT32, APT-C-00, SeaLotus, Sinh Tử Lệnh, Cobalt Kitty, and SectorF01, has been active since late 2009 and is believed to be based in Vietnam. The group has attacked Vietnamese bloggers and dissidents and launched targeted attacks on industrial and government entities in Vietnam, Cambodia, China, Laos, the Philippines, Germany, and the United States. Apart from phishing emails, OceanLotus carries out watering hole attacks.

APT name	Regions attacked	Operation start
OilRig	South Asia, Middle East	April 2020

In May 2020, Symantec published a report on the OilRig group's attacks against telecommunications companies in South Asia in April 2020. Researchers at Unit42 observed similar tactics and tools associated with attacks on a telecommunications organization in the Middle East in April 2020, specifically using custom Mimikatz tools, Bitvise, PowerShell downloaders and a custom backdoor the researchers track as RDAT. The backdoor in this campaign only uses DNS tunneling with TXT queries for its C&C communications.

The researchers first saw the RDAT tool used in OilRig's operations in 2017. It was uploaded to a webshell 11 days after the publication of Unit42's report on an OilRig campaign. It was apparently done in order to retain access to the server after the details of the campaign were exposed. The name was based on one of the discovered PDB paths:

- C:\Users\Void\Desktop\RDAT\client\x64\Release\client.pdb
- C:\Users\Void\Desktop\dns\client\x64\Release\client.pdb

Using the file path of the user in the PDB string of C:\Users\Void\Desktop, the researchers gathered over a dozen samples with that file path, with most of the samples identified as a known OilRig tool called ISMDOOR. It is likely that these have been developed by a single adversary or adversary group.

Since the start of the backdoor's development, researchers have observed several variations, which resulted in the tool's ability to rely on both HTTP and DNS tunneling and use Exchange Web Services (EWS) to send and receive emails for C&C communications. In some samples, C&C servers and email addresses are provided as arguments while in others they are hardcoded. To send emails from a compromised host, the backdoor uses the email associated with the account logged into the compromised host, as it uses the WinHTTP library to make requests to the API with the the WinHTTP library to make requests to the API with the WINHTTP_OPTION_AUTOLOGON_POLICY field set to WINHTTP_AUTOLOGON_SECURITY_LEVEL_LOW, which automatically attempts to log onto Exchange using the default credentials. The threat actors communicate with the backdoor by sending emails from one of two email addresses controlled by them to the email address of the compromised account.

In mid-September 2020, a report called *Rampant Kitten Campaign* was released. It describes a malicious campaign targeting Iranian minorities and anti-regime organizations such as the Association of Families of Camp Ashraf and Liberty Residents (AFALR), the Azerbaijan National Resistance Organization, and people of Balochistan. According to our data, part of the malicious infrastructure belongs to APT34. The following attack vectors were detected in this campaign:

- Emails with malicious documents that install infostealers intended to steal data from Telegram and KeePass
- Android backdoor that extracts two-factor authentication codes from SMS messages, records the phone's voice surroundings, and more
- Telegram phishing pages distributed using fake Telegram service accounts

In their conclusion, the researchers were not able to attribute these attacks to a particular APT group. However, the threat actors left digital fingerprints of Iranian origin. The records for one of the domains mentioned the email address nobody[.]gu3st@gmail[.]com. The same user was detected on Iranian hacker forums.

On January 9, 2020, our system for detecting malicious infrastructures recorded that the domain telegramco[.]org was used by ATP34. It also recorded that the domains telegrambackups[.]com and developerchrome[.]com were used by APT34 on May 23, 2020 and August 6, 2020.

OilRig (also known as APT34) has been active since late 2015. The group is based in Iran and is believed to be linked to the Iranian government. The threat actors mainly target the banking sector, airlines, educational institutions, government entities, and IT and telecommunications companies. The group had targets in Saudi Arabia, Turkey, Israel, Kuwait, Qatar, the US, the UAE, and Lebanon.

APT name	Regions attacked	Operation start
CharmingKitten	USA, Israel	July 2020

Since at least July 2020, the APT35 group has been using new TTPs in their attacks. The group's members pose as Jewish Journal and Deutsche Welle journalists using emails alongside WhatsApp messages as their main platform to approach their targets and convince them to open a malicious link. To gain the victim's trust, the attackers use fake LinkedIn profiles as well. In this campaign, security researchers identified attempts to attack Israeli scholars and US government employees. In addition, the threat actors attempted to contact their victims using WhatsApp calls and a legitimate German phone number.

In this campaign, the victims are offered to participate in an online webinar/meeting about Iran and other subjects of interest to the target. The CharmingKitten operators introduce themselves as journalists and

ask the victim whether they are interested in participating in the webinar. If so, they are requested to reply in order to receive the details, designed to gain the victim's trust.

Correspondence in WhatsApp could continue for a long time. In one case, the threat actors communicated with their victim for 10 days in an attempt to make them follow an account activation link to take part in the webinar, in which the victim was asked to be the main speaker. If the target refuses to share their phone number, the threat actors will send malicious links in messages on LinkedIn.

The malicious link is embedded in a legitimate, compromised Deutsche Welle domain with waterhole methods. Each victim receives a personalized link tailored to their specific email account. After following the link, the victim is asked to sign in using any of the options offered, such us Google, Microsoft, Yahoo, and Apple.

The group used a similar tactic in its attacks against ClearSky users. The threat actors registered a domain mimicking a legitimate one belonging to the company. The difference from the legitimate website was in a similar authentication form, which was able to intercept login-password pairs as well as two-factor authentication codes.

Moreover, an attempt to send a malicious ZIP file to the victim was discovered, in addition to a message that was sent to the victim via a fake LinkedIn profile. Through that account, the threat actors planned to use two vectors:

- An email with a malicious link
- An email with a malicious file attached

The Iranian threat group APT35 (also known as Phosphorus, Charming Kitten, Ajax Security Team, Newscaster, Group 83, and Parastoo) has been carrying out attacks since at least 2013. The group focuses on individuals of interest to Iran who work in the fields of academic research, human rights, and media, with most victims located in Iran, the United States, Israel, and the UK. The hackers usually try to gain access to private email and Facebook accounts and sometimes establish a foothold on victim computers as a secondary objective.

APT name	Regions attacked	Operation start
Lazarus	South Korea, India, Russia, Europe	March 2020

In June 2020, Lazarus registered a malicious HWP document in a notice on the Korean Academy of Medical Sciences (KAMS) website and distributed malware. The notice is about temporary permission for online academic conferences. The personal information of doctors, including license numbers and account information, was stolen from the Korean Academy of Medical Sciences website. It was later found that the Trojan that was distributed through hacked KAMS (CRat) was also sent to doctors in spear-phishing attacks. Lazarus is believed to be carrying out additional attacks involving doctors' personal emails stolen from the KAMS.

Group-IB's Threat Intelligence system detected the upload of a file called "Boeing_Russia_AA.docx" to VirusTotal from an IP address in Russia on July 23, 2020, at 10:57 p.m. UTC+03:00.

Victims were shown a vacancy at Boeing. According to the metadata, the document was edited on July 21, 2020.

Based on Lazarus's previous attacks against military-industrial complexes in Europe and the United States, as well as attacks against a nuclear power plant in India, we believe that this attack may have been carried out using a malicious email, messaging apps (WhatsApp, Skype), or social media (e.g., LinkedIn).

When the malicious email is opened, a remote document with a macro is downloaded from hxxps://docentfx[.]com/wp-includes/theme-compat/logo/b_r_205699.jpg and is then executed.

As a result, the CuriousLoader desktop.dat loader will be downloaded and launched on the victim's computer using the rundll32.exe system utility.

The loader collects information about the system and sends it to the C&C server at www.fabianiarte[.]com, which is used by the North Korean hackers to cover the traces of compromise and avoid detection by security tools.

The operator examines the data collected by the reconnaissance module (CuriousLoader) and if the victim is interesting, whitelists the IP address. The module then receives the next state — Manuscrypt.

The Manuscrypt Trojan uses compromised legitimate websites as C&C servers.

Group-IB specialists obtained a whitelist from a C&C server and discovered IP addresses associated with a Russian organization that develops and manufactures military equipment for anti-aircraft warfare and missile defense.

The compromised website www.fabianiarte[.]com is also associated with another Lazarus mailout when the group posed as an employer on behalf of BAE Systems, which is a British defense company that specializes in military equipment, information security, and aerospace sector.

In addition, it was discovered that Lazarus started using new ransomware, which was dubbed VHD.

Functionally, VHD is a fairly standard ransomware tool. It creeps through the drives connected to a victim's computer, encrypts files, and deletes all System Volume Information folders (thereby sabotaging System Restore attempts in Windows). Moreover, it can suspend processes that could potentially protect important files from modification (such as Microsoft Exchange or SQL Server).

Files are encrypted with a combination of AES-256 in ECB mode and RSA-2048.

Experts examined two incidents related to VHD and analyzed the threat actors' actions; they note that the Trojan's delivery mechanisms are more typical of sophisticated targeted attacks.

In the first incident, the experts' attention was drawn to the malicious code responsible for spreading VHD over the target network. It turned out that the ransomware had at its disposal lists of IP addresses of victim computers, as well as credentials for accounts with admin rights. It used that data for brute-force attacks on the SMB service. If the malware managed to connect using the SMB protocol to the network folder of another computer, it copied and executed itself through WMI (Windows Management Instrumentation) calls, encrypting that machine.

The experts believe that such behavior is not very typical of mass ransomware. It suggests at least a preliminary reconnaissance of the victim's infrastructure, which is more characteristic of APT campaigns.

In their analysis of the second incident, the experts were able to trace the entire infection chain, during which the threat actors:

- Gained access to victims' systems by exploiting a vulnerable VPN gateway
- Obtained admin rights on the compromised machines
- Installed a backdoor
- Seized control of the Active Directory server
- Infected all computers on the network with the VHD ransomware using a loader specially written for the task. The entire process took place over the course of ten hours.

Further analysis of the tools employed showed that Dacls was the backdoor that the threat actors used.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group's members are from North Korea.

APT name	Regions attacked	Operation start
Transparent Tribe	India, Canada, USA, UK, Australia, Japan, China, Mongolia, Nepal, Pakistan, Malaysia, Thailand, Afghanistan, Turkey, Bulgaria, Iran, Saudi Arabia, Germany, Netherlands, Belgium, Sweden, Spain, Mexico, Bangladesh, Oman, Botswana, Kenya	June 2019

Security experts discovered samples related to Transparent Tribe Crimson components. Considering all components detected between June 2019 and June 2020, the specialists found more than one thousand distinct victims distributed across 27 countries.

Most of the detections were related to USB Worm components; and in most of the countries, the number of events was very low.

USBWorm is a component developed for stealing files from removable drives; spreading across systems by infecting removable media; and downloading and executing the "Thin Client" component from a remote Crimson server.

USBWorm is much more than a USB infector; it can be used by the attacker to:

- Download and execute the Crimson "Thin Client"
- Infect removable devices with a copy of USBWorm itself
- Steal files of interest from removable devices (i.e., USB Stealer)

By default, the program behaves as a downloader, infector, and USB stealer. Usually, the component is installed by the Crimson "Main Client" and when started it checks if its execution path is the one specified in the embedded configuration and if the system is already infected with a Crimson client component. If these conditions are met, it will start to monitor removable media, and for each of these, the malware will try to infect the device and steal files of interest.

The infection procedure lists all directories. Then, for each directory, it creates a copy of itself in the drive root directory using the same directory name and changing the directory attribute to "hidden." This results in all the actual directories being hidden and replaced with a copy of the malware using the same directory name.

Moreover, USBWorm uses an icon that mimics a Windows directory, tricking the user into executing the malware when trying to access a directory.

The data theft procedure lists all files stored on the device and copies those with an extension matching a predefined list:

File extensions of interest: .pdf, .doc, .docx, .xls, .xlsx, .ppt, .pptx, .pps, .ppsx, .txt.

If a file is of interest and is not on the list of stolen files, it will be copied from the USB to a local directory usually named "data" or "udata."

If the worm is executed from removable media, the behavior is different. In this case, it will check if the "Thin Client" or the "Main Client" is running on the system. If the system is not infected, it will connect to a remote Crimson Server and try to use a specific "USBW" command to download and execute the "Thin Client" component.

In addition, Q3 saw the discovery of a new Android implant used by Transparent Tribe for spying on mobile devices. The attack starts with a simple document, which is not malicious by itself, does not contain any macro, and does not try to download other malicious components; however, it uses social engineering tricks to lure the victim into downloading other documents from an external source.

An analysis of the domains of these sources revealed a file that is a modified version of MxVideoPlayer, a simple open-source video player for Android, downloadable from GitHub and used by Transparent Tribe to drop and execute their Android RAT.

The dropper tries to find a list of legitimate packages on the system:

- imo.android.imoim
- Snapchat.android
- viber.voip
- facebook.lite

If the device was produced by Xiaomi, it also checks if the com.truecaller package is present.

The first application on the list that is not installed on the system will be selected as the target application. The malware embeds multiple APK files, which are stored in a directory named "assets."

The selected APK is copied to /.System/APK/. By default, the application tries to save the file to external storage, otherwise it saves it to the data directory.

Finally, the application tries to install the copied APK. The final malware is a modified version of the AhMyth Android RAT, open-source malware downloadable from GitHub, which is built by binding the malicious payload inside other legitimate applications.

The original AhMyth RAT provides the following features:

- Camera manager (lists devices and steals screenshots)
- File manager (enumerates files and uploads them to the C&C)
- SMS manager (gets a list of text messages or sends a text)
- Gets the call log
- Gets the contact list
- Microphone manager
- Location manager (tracks device location)

The RAT analyzed by the experts is slightly different from the original. It includes new features added by the attackers to improve data exfiltration, while some of the core features, such as the ability to steal pictures from the camera, are missing.

Moreover, the creators of the RAT also improved its audio surveillance capabilities and included a command to delete text messages with specific contents.

Transparent Tribe is taking advantage of pandemic-tracking applications to distribute trojanized code. Specifically, the specialists found an APK file imitating Aarogya Setu, a COVID-19 tracking mobile application developed by the National Informatics Centre under the Ministry of Electronics and Information Technology, Government of India. It allows users to connect to essential health services in India.

Based on public information, the application may have been distributed by sending a malicious link via WhatsApp, SMS, phishing email, or social media.

Transparent Tribe (also known as APT36, ProjectM, Mythic Leopard, and TEMP.Lapis) is a Pakistani threat group active since 2012. Transparent Tribe carries out cyber espionage operations with the aim of collecting confidential information from India to support Pakistani military and diplomatic interests.

APT name	Regions attacked	Operation start
StrongPity	Colombia, India, Canada, Vietnam, Russia, Poland, Germany, South Africa, Italy, France, USA, Netherlands	March 2018

StrongPity is expanding its reach and attempts to infect new targets across several countries. Samples related to StrongPity3 targeted victims in Colombia, India, Canada and Vietnam. The group has at least four new trojanized setup files, which researchers observed: Firefox (browser), VPNpro (VPN client), DriverPack (pack of drivers), and 5kPlayer (media player).

The experts could not pinpoint the initial attack vector; however, the use of trojanized installation files of well-known applications is consistent with previously documented campaigns. This suggests that just like in the past, the initial vector may be either a watering hole attack or in-path request interception.

Many different versions of the malware, coupled with the fact that the domains are hardcoded indicates that a tool such as a Builder is used to generate binaries.

StrongPity3 is the evolution of StrongPity2, with a few differences. The latter does not use libcurl anymore and now uses winhttp to perform all requests to C&C. The usage of the HKCU\Software\Microsoft\Windows\CurrentVersion\Run registry key has a persistence mechanism that has been replaced by the creation of a service. This service changes its name from package to package. The service executable's only job is to launch the C&C contact module upon service startup. The remaining malware flow is the same on both versions.

PROMETHIUM is a group of hackers believed to be from Turkey. The group is also known as StrongPity and was active as early as 2012. Information about this threat group was first published in October 2016 with details about the group's attacks against users in Belgium and Italy. In 2018, the threat actors shifted their focus to a different region and targeted Turkish telecommunications companies in order to attack hundreds of users in Turkey and Syria.

After first being documented, the threat actors changed their toolkit but not their techniques or procedures. Since then, their toolkit has been the same, with just enough updates to keep their activities as efficient as possible. During this period, the victimology has expanded beyond their initial focus on Europe and the Middle East to a global operation targeting organizations on most continents.

These characteristics can be interpreted as signs that this threat group could in fact be part of an enterprise service for hire operation.

APT name	Regions attacked	Operation start
APT15	Western China	2013

Security specialists discovered a yearslong campaign targeting the Uyghur Muslim ethnic minority group mostly living in the west of China.

As part of this campaign, people's devices have been infected with malware since 2013, which allowed the hackers to monitor the activities of Uyghur communities in the border regions of China and abroad in at least 14 countries.

The experts are confident that a hacker group operating under the auspices of the Chinese government is behind this campaign. Some of the previous operations of this group were documented by other information security experts, and in the past, the group received the code name APT15.

Most of the past APT15 attacks were related to Windows malware, but the hackers now also have Android tools in their arsenal. Some of them were already known to experts earlier, including malware varieties such as HenBox, PluginPhantom, Spywaller, and DarthPusher. Besides, the analysts discovered four new malicious programs: SilkBean, DoubleAgent, CarbonSteal, and GoldenEagle.

The researchers note that APT15 did not upload its malicious applications to the Google Play store; rather, the group hacked into various legitimate sites and used the watering hole technique.

The experts say that in the early stages of exploring the new APT15 malware, they discovered a GoldenEagle spyware C&C server, which the hackers mistakenly left unprotected. The researchers gained access to this server and collected information about both victims and the operators.

Looking through logs obtained this way, the researchers found data from the first devices infected with GoldenEagle. It turned out that the GPS coordinates obtained from these devices were concentrated around the same area. It was then established that these were the GPS coordinates of a building in Xi'an, central China, where the office of Xi'an Tianhe Defense Technology, a major military contractor, was located.

The researchers believe that these initial infections appear to be related to devices infected at an early malware development. Considering their GPS coordinates, the researchers assume that these are test devices on which the developers of the GoldenEagle Malvari tested the operation of their malware. The developers seem to be the engineers of Xi'an Tianhe Defense Technology.

APT15 (also known as Ke3chang, Mirage, Vixen Panda GREF, and Playful Dragon) is a cybercriminal group believed to be based in China. The threat actors have been active since at least 2010. Their aim is cyber espionage against diplomatic organizations in Europe.

APT name	Regions attacked	Operation start

Kimsuky	South Korea	October 2019

New activity of the Kimsuky threat group was detected. The malware is in the same style as "KINU Expert Advisory Request.hwp," which was released in October 2019.

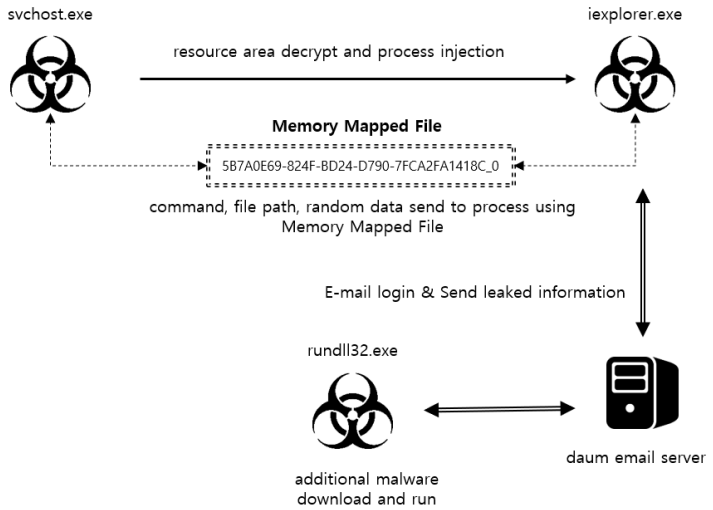
The exploit code and shellcode in the variable **/ar** are almost the same as before, but the XOR key was changed from 0x00 to ox91. The decoding and comparison of the exploit code and the shell code revealed that they were the same except for the signature code.

As before, the decoded shellcode is injected into “himtrayicon.exe.” The injected shellcode decrypts the encrypted malicious code and injects it into the userinit.exe process.

The malware injected into the userinit.exe process was the same as previously; only the C&C address, the name of the downloaded file, and the mutex name changed. The attacker sends stolen data to the C&C and downloads additional malicious code. The downloaded file is XOR encoded in 0xFF. Interestingly, it has the wrong mutex name.

The downloaded malware is packed with VMProtect. The main malicious behaviour, however, is almost the same as before. In the past, the folder name was disguised as defender, while in this case, it was disguised as firefox. In particular, the attacker used the folder name as firefax, not firefox. After the malicious code steals system information, it decrypts the encrypted PE file in the resource area and injects it into svchost.exe.

The malicious code injected into svchost.exe compresses and encrypts the stolen information, injects the malicious code into iexplorer.exe, and requests file upload. iexplorer.exe reads the mapping file named “mutexname_0,” connects to the Daum email service, and uploads and downloads files according to the command.



Kimsuky (also known as Velvet Chollima and Black Banshee) is a hacker group believed to be based in North Korea. The group has been actively attacking entities in the South Korean territory since 2010, but has lately been expanding the geographical scope of their attacks.

APT name	Regions attacked	Operation start
APT37	South Korea, Asia-Pacific region	July 2020

In July 2020, the APT37 group was highly active.

At the time, the email subject in the spear-phishing attack featured북한 핵 실험장 지역 인근 출신 탈북민 명단-1.hwp [List of North Korean defectors from the North Korean nuclear test site -1.hwp]. A typical social engineering technique was used to make users read documents by inserting a Google Drive link in the body of the email.

Since then, several other attack attempts have been discovered, with reporters from media groups being targeted.

The attack was mainly aimed at the free email service of a privately used domestic portal company, not the company's official email address.

The case reported on August 11 is disguised as the official content sent by the email service security team as an account error confirmation request, and the method of attempting to steal the password by inducing identity verification was utilized.

In addition, on August 24, reconnaissance activity was captured to check for clicks by disguising as a confirmation of using a specific cloud gallery.

The threat actors use not only traditional click-to-action attacks, but also two-track strategic tactics that prompt execution by the attachment of malicious files.

On August 24, an attack was carried out against a journalist at a media company involving an attached malicious document called "한반도 정세와 안보패러다임 전환 [the Korean peninsula situation and security paradigm shift]. In addition, scripts such as WSF, JSE, and LNK shortcut techniques were also used.

In addition, mainly HWP and DOC document file-based attacks and double-extension EXE executable files disguised as documents are used depending on the situation. A number of signs of attack were detected between August 28 and September 2.

Recently, newly detected threat cases were documents containing the contents of research on the relations of workers in the Kaesong Industrial Complex and decoy files disguised as submissions for research papers in the Asia-Pacific region.

APT37 (also known as Group123, Reaper, ScarCruft, Geumseong121, Red Eyes, Ricochet Chollima, Venus 121, Thallium, Hermit, and KONNI) is a cyber espionage group active since at least 2012 and believed to be acting in the interests of the North Korean government. The group mainly targets government, defense, military, and media organizations in South Korea. In 2017, the group's geographical scope was extended to Japan, Vietnam, and the Middle East. Targeted sectors include the healthcare, chemicals, manufacturing, aerospace, and automotive industries.

APT name	Regions attacked	Operation start
RedCurl	Russia, Ukraine, Canada, Germany, UK, Norway	2018

One summer evening in 2019, CERT-GIB (Group-IB's Computer Emergency Response Team) received a call from a new customer who said that their company had been attacked. They asked for help in eliminating the incident's aftermath and identifying the hacker group responsible.

The duty CERT-GIB analyst examined the phishing email used at the initial infection stage. It was particularly well written, which suggested that this was a planned targeted attack. The unique behavioral fingerprint — obtained as a result of dynamic analysis in TDS Polygon — confirmed the analyst's

hypothesis. They immediately notified Group-IB's Threat Intelligence team about the incident and within a couple of hours the customer was informed about the targeted attack against their business.

Meanwhile, the email sample and the attack details caught the attention of Group-IB's Threat Intelligence specialists. The campaign conducted by the hacker group (unknown at the time) involved unique tools written in PowerShell, which is popular among IT specialists. Moreover, the emails targeted a specific team within the victim organization rather than the organization as a whole.

Group-IB named the group of hackers, which engaged in cyber espionage, RedCurl.

Detected incidents related to this threat group took place in various industries and had a wide geographical scope: from Russia to North America.

Since 2018, Group-IB has detected 26 attacks against targets in various industries, including:

- Construction companies
- Retailers
- Insurance companies
- Financial companies
- Banks
- Law and consulting firms

Group-IB has identified 14 organizations that have become victims of RedCurl's espionage attacks, some on several occasions.

It is likely that the attacks were ordered for the purpose of corporate espionage. This hypothesis is reinforced by the fact that the group acted as covertly as possible in order to minimize the risk of being discovered on the victim's network. For instance, RedCurl did not use actively communicating Trojans or remote administration tools with a graphical interface. It should also be noted that RedCurl uses techniques similar to those used by Red Teaming and penetration testing specialists.

APT name	Regions attacked	Operation start
APT39	USA, UK, Africa, Singapore, Australia, Israel	2015

On September 17, 2020, the US Department of the Treasury's Office of Foreign Assets Control (OFAC) imposed sanctions on APT39, 45 associated individuals, and one front company called Rana Intelligence Computing Company (Rana). Concurrent with OFAC's action, the US Federal Bureau of Investigation (FBI) released information about some of APT39's attacks.

According to OFAC, Rana advances Iranian national security objectives and the strategic goals of Iran's Ministry of Intelligence and Security (MOIS) by conducting computer intrusions and malware campaigns against perceived adversaries, including foreign governments and other individuals the MOIS considers a threat.

The 45 designated individuals served in various capacities while employed at Rana, including as managers, programmers, and hacking experts. OFAC says that these individuals used malicious cyber intrusion tools to target Iranian dissidents and journalists, former government employees, environmentalists, refugees, university students and faculty, and employees at international nongovernmental organizations. Rana's targeting has been both internal to Iran and global in scale, including hundreds of individuals and entities from more than 30 different countries across Asia, Africa, Europe, and North America.

The FBI advisory details eight separate and distinct sets of malware used by MOIS through Rana to conduct their computer intrusion activities:

- Visual Basic Script (VBS)
- AutoIt Malware
- BITS 1.0 and BITS 2.0 Malware
- Firefox Malware
- Python-Based Malware
- Android Malware
- Depot.dat Malware

The Chafer group (also known as APT39, ITG07, and TA454) has been active since at least 2014. The threat actors' main objective is to collect information that allows them to track targets related to Iran's national priorities or use them as additional access opportunities to facilitate future campaigns. The group's activities are concentrated in the Middle East. Chafer has prioritized the telecommunications sector, with additional targeting of the travel industry and IT firms that act as contractors of the companies in which the group is interested.

APT name	Regions attacked	Operation start
Gaza Cybergang	Middle East	October 2019

Security specialists discovered a malicious Android app called Welcome Chat. It was distributed through a website where users were offered a new secure chat app that was claimed to be available on Google Play.

In reality, this was an espionage tool and its operators left the data harvested from their victims freely available on the Internet. In addition, the app was never available on Google's official app store.

The malware mostly targets Arabic-speaking users in the Middle East. The researchers believe that the Gaza Cybergang threat group, also known as Molerats, is behind the development of this malware.

After installation, Welcome Chat will request the victim to allow permissions such as send and view SMS messages, access files, record audio, and access contacts and device location. This allows the app to receive commands from the C&C server and transfer the collected information to the operators.

On top of its core espionage functionality – monitoring the chat communications of its users – the Welcome Chat app can exfiltrate:

- Sent and received SMS messages
- Call log history
- Contact list
- User photos
- Recorded phone calls
- The GPS location of the device and device info

The researchers say that most of the malicious code was copied from publicly available open source code projects and code example snippets available on public forums. Apparently, the creators of Welcome Chat did not put a lot of time and effort into developing the app. They seem to have used code that appears at the top of search engine results. Some parts of the code are five to eight years old.

Gaza Cybergang (Molerats) has been active since 2012 and has been mainly targeting government agencies in the MENA region. The attackers use phishing emails, paste sites hosting malware stages, social engineering methods, and different RATs. The group's goal is to collect intelligence data.

APT name	Regions attacked	Operation start
Chinese APT group that uses a new MgBot variant	India, Hong Kong	July 2020

On July 2, security specialists found an archive file with an embedded document purporting to be from the government of India. This file used template injection to drop a malicious template, which loaded a variant of Cobalt Strike.

The next day, the same threat actor changed their template and dropped a loader called MgBot, executing and injecting its final payload through the use of Application Management (AppMgmt) Service in Windows.

On July 5, the experts observed yet another archive file with an embedded document borrowing a statement about Hong Kong from UK Prime Minister Boris Johnson. This document used the same TTPs to drop and execute the same payload.

Considering the ongoing tensions between India and China, as well as the new security laws in Hong Kong, the experts believe this new campaign is operated by a Chinese state-sponsored actor that has been active since at least 2014.

The new loader variant called MgBot (BLame, Mgmbot) purports to be Realtek Audio Manager.

The loader starts its process by escalating privileges through a UAC bypass using the CMSTPLUA COM interface.

MgBot uses several anti-analysis and anti-virtualization techniques. The code is self-modifying, which means it alters its code sections during runtime. This makes static analysis of the sample harder.

The specialists were able to identify several different variants of the loader. In general, all the variants drop the final payload using expand.exe or extrac32.exe and then use “net start AppMgmt” or “net start StiSvc” to execute the dropped DLL with one of the following configurations:

- svchost.exe -k netsvcs -p -s AppMgmt
- svchost.exe -k netsvcs
- svchost.exe -k imgsvc

The dropped DLL is the main payload used by this threat actor to perform malicious activities. According to the file version information, it purports to be Video Team Desktop App.

The final piece of code bundled in MgBot is a remote administration Trojan with several capabilities such as:

- C&C communication over TCP
- Ability to take screenshots
- Keylogging
- File and directory management
- Process management
- MUTEX creation

The TTPs observed in these attacks have been used by several Chinese APT groups:

- Rancor APT is known to have been using Certutil to download their payload.
- KeyBoy is known to have used DDE in its previous campaigns.
- APT40 utilized Squiblydoo and template injection in its previous campaigns.

APT name	Regions attacked	Operation start
Gamaredon group	Ukraine	2020

In July–September 2020, the Gamaredon group continued its attacks against Ukraine's Security Service and Ministry of Foreign Affairs.

The topic of the decoy document usually related to the armed conflict in Ukraine. For instance, campaigns were detected that aimed at distributing documents on behalf of JCCC (the Joint Centre for Control and Coordination on ceasefire in Donbass). The email addresses used for sending out the emails were designed to look similar to typical ones used in the sector (e.g., АТЦ (в/ч Р9163) [Anti-Terrorist Center (military unit R9163)] atc@kyiv-mail.site and sv.ssu@ua-email.online to mimic briefing mailout by the Security Service of Ukraine).

In the September 2020 attacks, the popular topics were solicitations for checks of individuals associated with Ukraine's Security Service; violation reports; and even a student's placement application. After one such attack, the Security Service initiated a sinkhole process in relation to the attackers' resources.

Attacks intensified in mid-August 2020, presumably on the occasion of Ukraine's Independence Day.

In addition, an email to the Prosecutor's Office of the Autonomous Republic of Crimea was detected. Such actions may indicate collection of information about information security tools and an attempt to proxy a malware mailout through automatic forwarding to the current standard address of the Prosecutor General's Office of Ukraine.

IP addresses were detected, which hosted a big number of resources potentially intended for the group's attacks. The attribution of many of the detected resources was confirmed by discovered samples typical of the attacks in this campaign.

The C&C servers in most cases are hosted using a DyDNS service. The domain names resemble ones generated using a domain generation algorithm (DGA).

Moreover, a new way of sending signals to the C&C server was detected: a POST request to the resource along with transfer of the computer name and system disk serial number through the **cash** field. The loading of a second-stage module is implemented through an alternative channel by creating a GET request.

The principle of creating a URI mask for the second-stage payload was changed: the latest attacks involved the use of masks as standard UNIX system paths (e.g., /lib/cache/). Many attacks have non-standard masks.

In addition, there was a change in the pattern of naming DOT files (vulnerability CVE-2017-0199, the template injection technique) that are the second-stage module: template files now have randomized names (e.g., gJHEIw.dot).

The payload in the DOT files is still VBA macros. However, a new attack pattern was also discovered: the mailout of archives with the MSHTA.EXE system component mimicking an LNK file. Clicking on it initiates the main module through the PowerShell commandlet start-process.

Gamaredon Group (also known as Primitive Bear) is a Russian threat group active since at least 2013. At first, the threat actors used to borrow tools for their attacks, but then started using their own malware. The group's attacks target governments, law enforcement agencies, and military organizations mostly in Ukraine.

APT name	Regions attacked	Operation start
APT40	-	April 2020

Microsoft announced that a Chinese state-sponsored threat group called Gadolinium (also known as APT40 and Leviathan) created and used 18 Azure Active Directory applications to attack Microsoft Azure customers. All of the detected applications were removed from the Azure portal in April this year.

A new tactic employed by the group was discovered, of which the malicious Azure Active Directory applications were part. The specialists described the attack routine as "particularly challenging" to detect due to its multi-stage infection process and the broad use of PowerShell payloads.

These attacks began with spear-phishing emails aimed at the target organizations, carrying malicious documents, usually PowerPoint files with a COVID-19 theme. Victims who opened one of these documents would be infected with PowerShell-based malware payloads. That was where the malicious Azure AD apps would also come into play.

The PowerShell malware was used to install one of the 18 Azure AD apps on victim computers. The role of these apps was to automatically configure the victims' endpoints "with the permissions needed to exfiltrate data to the attacker's own Microsoft OneDrive storage."

APT40 (also known as Leviathan, TEMP.Periscope, TEMP.Jumper, Bronze Mohawk, and Mudcarp) is a cyberespionage group sponsored by China and active since at least 2013. The threat actors hack the networks of defense organizations and steal confidential technical drawings and other information that can be used to modernize the Chinese navy and influence foreign elections.

APT name	Regions attacked	Operation start
APT41	Russia, USA, Japan, South Korea, Germany, Mongolia, Belarus, India, Brazil	2020

Security experts discovered a new attack by the Winnti hacker group, which infected several dozen computers around the world (over 50), including Russia, the US, Japan, South Korea, Germany, Mongolia, Belarus, India, Brazil, etc.

Some of the compromised organizations were identified:

- A university in the United States
- An audit firm in the Netherlands
- Two construction companies (one in Russia, the other in China)
- Five software developers (one in Germany, four in Russia)

It appears that this was a supply chain attack at an early stage. In particular, the attacked vendors of specific software, which are trusted software vendors for a number of companies, are likely to be used as a springboard for further development of the attack.

In addition, the specialists identified a previously unknown xDll backdoor, as well as a number of other samples of malware, both known and new (SkinnyD, Python backdoor).

The group's new infrastructure is reportedly expanding rapidly, with over 150 IP addresses of C&C servers and at least 147 domains associated with these addresses. About half of the group's servers are located

in Hong Kong. The IP addresses are distributed across 45 unique providers, while more than half of the servers are concentrated on the IP addresses of six providers, five of which are located in Asia (Hong Kong, China, and South Korea).

The xDll backdoor is an executable file written in C++ and compiled in Microsoft Visual Studio using the MFC library.

It starts by scouting the system and collects the following information:

- Computer name
- IP address
- OEM code page
- MAC address (used later on to calculate the MD5 hash sum for C&C interactions)
- OS version
- The preset identifier "sssss" (probably characteristic of this particular version of the backdoor)
- Whether the user is an admin
- Whether it is in a virtual environment
- Domain and username
- CPU information
- RAM information
- System language

SkinnyD (Skinny Downloader) is a simple downloader: it contains several C&C addresses and goes through them one by one.

The next stage is downloaded with a GET request to the C&C server via a special URL address generated according to a format string hardcoded in the malware code.

In September 2020, the US government filed charges against five Chinese nationals suspected of being part of the APT41 group.

According to unsealed court documents, the group hacked software development companies, computer hardware manufacturers, telecommunications providers, social media companies, video game companies, healthcare, non-profit organizations, universities, think tanks, from where they stole proprietary source code, code-signing certificates, customer data, and valuable business information.

Victim companies resided in countries such as the US, Australia, Brazil, Chile, Hong Kong, India, Indonesia, Japan, Malaysia, Pakistan, Singapore, South Korea, Taiwan, Thailand, and Vietnam. US officials said APT41 members also compromised foreign government computer networks in India and Vietnam, as well as pro-democracy politicians and activists in Hong Kong. Attacks against the UK government were also executed, but were not successful.

According to court documents, the first two APT41 members were identified and charged in August 2019, following a FireEye report. According to a copy of the 2019 indictment, these charges stemmed from alleged attacks against high technology and video gaming companies, and a United Kingdom citizen. The two suspects were identified as Zhang Haoran (张浩然), 35, and Tan Dailin (谭戴林), 35.

Another three APT41 members were charged in a separate indictment filed a year later, in August 2020. According to the documents, Jiang Lizhi (蒋立志), 35, Qian Chuan (钱川), 39, and Fu Qiang (付强), 37, were charged with most of APT41's intrusions.

US officials said the three were employees of Chengdu 404 Network Technology, a front company that operated under the close supervision of PRC officials. The court documents also revealed intercepted online chats between Jiang and other Chinese hackers, conversations where Jiang touted knowing and operating under a high-ranking official in the Chinese Ministry of Public Security.

In addition, two Malaysian businessmen were also charged for conspiring with Winnti members to profit from intrusions against video game companies. The two were arrested on Monday, September 14, 2020 in Malaysia.

According to court documents, the two were identified as Wong Ong Hua, 46, and Ling Yang Ching, 32, owners of Sea Gamer Mall, a website that sold digital currency for various online games. US officials believe that the currency was sometimes provided by APT41 members illegally, following intrusions against gaming companies.

APT41 (also known as BARIUM, Winnti, LEAD, Axiom, Group 72, and Double Dragon) is a Chinese state-sponsored threat group active since 2012. The group's espionage campaigns have targeted healthcare, telecommunications and high-tech sectors and have historically involved intellectual property theft. APT41's attacks have targeted the gaming industry and included the manipulation of virtual currencies and attempted deployment of ransomware.

APT name	Regions attacked	Operation start
ReconHellcat	Azerbaijan, Bulgaria	March 2020

On August 5, a compressed archive containing a macro-enabled Word document related to the recent Beirut explosion was uploaded to VirusTotal from Azerbaijan. The name of the file ("047-20 – OSCE Report Beirut explosion.doc") might indicate the attackers' intent to spoof the Organization for Security and Co-operation in Europe (OSCE); however, security specialists discovered that the attackers weaponized a legitimate Word document available on the web portal of the Organismo Supervisor de las Contrataciones del Estado (OSCE), which is a supervisory body of the Peruvian Ministry of Economy.

The document contains an obfuscated macro that retrieves the second-stage encrypted payload from one of three hardcoded C&C URLs depending on the user's Windows version. To decrypt the payload, the attackers implemented an old-fashion substitution cipher technique, Book cipher, using the legitimate Windows file C:\Windows\Fonts\cambriab.tff as a key. The content of this file differs depending on the Windows version, which is why the malicious macro checks the Windows version at the beginning of its execution and contacts a specific URL depending on the result of this check. Finally, the decrypted payload is written in %APPDATA%\\Microsoft\Word\STARTUP\Moon.wll. Storing a Word add-in in this path allows Microsoft Word to load and execute malicious payload whenever it is launched.

The malicious Moon.wll contains another encrypted set of three different C&C URLs and once executed by Word downloads an encrypted x64 executable as the final backdoor. The decryption technique used to decrypt the x64 backdoor still uses the Windows font file as a key; however, the C&C URL is passed as an encrypted parameter, which is decrypted via a different substitution cipher relying on a hardcoded alphabet as a key.

Finally, the Blackwater backdoor starts communicating with a Clouldflare Worker via JSON. Notably, both the loader and the backdoor resolve the C&C hostnames via DNS-over-HTTP (DoH) by using a built-in feature of libcurl. Only the malicious macro uses the system's default DNS server to get the first-stage payload.

The C&C infrastructure was hosted on the Cloudflare Workers platform, which is a service that enables users to register a subdomain and then have serverless code running to handle requests.

Since security specialists have not yet found any solid overlap with any already known APT group, the threat group behind two BlackWater campaigns was dubbed ReconHellcat.

APT name	Regions attacked	Operation start

Tonto Team	Eastern Europe	March 2019

In recent attacks targeting military and financial organizations in Eastern Europe, Tonto Team used a new variant of the Bisonal backdoor. Security specialists have not yet established how the threat actors infected system in their recent campaign. In previous attacks, Tonto Team used spear phishing to exploit unpatched vulnerabilities and infiltrate systems.

Once on the system, the malware sends various information about the victim's network to the attacker's C&C server, including the hostname, IP and MAC address, OS version, time of infection, and data on proxy or virtual environment usage. The backdoor functionality includes the ability to remotely launch a shell, invisibly launch programs, retrieve a list of processes, terminate processes, load/unload/delete files, and retrieve a list of drivers and files from a specific folder.

In addition to Bisonal, the group's arsenal includes custom versions of Mimikatz and keyloggers for stealing credentials and escalating privileges, as well as the DoubleT backdoor.

The Tonto Team APT (also known as CactusPete and Karma Panda) has been active since 2013 and is believed to be linked to the Chinese military, since, according to researchers, it is related to the Shenyang Military Region Technical Reconnaissance Bureau. The threat group typically targets military and diplomatic organizations as well as infrastructures in Asia and Eastern Europe.

APT name	Regions attacked	Operation start
Targeted attacks involving the Indian government's Parichay SSO platform as a decoy	India	2020

Security specialists discovered a recent campaign targeting employees of Indian government agencies, in which Parichay [parichay.nic.in] (the official single sign-on (SSO) platform of the Government of India) was used as a lure. An SSO is a session and user authentication service that permits a user to use one set of login credentials to access multiple applications. This activity raises concern among Indian government entities as well as entities linked to government agencies.

Based on an analysis, the attribution remains unclear as the payload and sample signature referenced publicly point this threat campaign to two distinct threat groups, publicly known as the North Korean group DarkHotel and Donot Team (APT-C-35).

The generic TTP identified in this campaign is such that the adversary sends an email to the victim with a Word document titled "Verification Form for PARICHAY Account.docx," which seems to be quite realistic and lures the victim into opening it.

This word document has an embedded link to a remotely hosted template file, which is a malicious RTF file. The file is designed to exploit a Microsoft Equation Editor remote code execution vulnerability (CVE-2017-11882). When the victim opens the Word document, the remotely hosted template file is executed, thus triggering the exploit, which in turn executes malicious binary code embedded in the RTF file. The binary is the final payload, which establishes connection to the adversary's C&C server and awaits further commands.

The payload checks for antivirus software installed on the host and collects the data in "InfoLog.txt." If no antivirus software is installed, it simply stores "NON" in text a file. In addition, the loader is meant to collect information about installed hot patches, Windows versions, and username by querying registry keys.

The final payload, DUser.dll is responsible for establishing C&C communication and is loaded by "credwiz.exe." DUser.dll is responsible for stealing interesting files and uploading to the adversary's C&C server by connecting over an arbitrary port using the standard Windows library "winsock." The loading in "credswiz.exe," which is a signed binary by Microsoft, makes it quite difficult to detect this payload, causing it run under the legitimate application.

APT name	Regions attacked	Operation start
TA413	Europe	March 2020

Security experts discovered a link between COVID-19–themed attacks against economic, diplomatic, and legislative entities within Europe, in which TA413 hackers posed as the World Health Organization, and recently detected attacks on the Tibetan community. The cyberattacks involved various malware: traditional tools such as ExileRAT and LuckyCat as well as the new Sepulcher malware.

The experts believe that all of the cyberattacks were carried out by the TA413 group, because in the July campaign targeting Tibetan dissidents the threat actors attempted to deliver the same Sepulcher malware from the same infrastructure, with some of the employed email addresses previously used in attacks delivering ExileRAT.

TA413's new Sepulcher malware can conduct reconnaissance on the infected host and supports reverse command shell and reading and writing from/to file. Based on received commands, it can gather information about drives, files, directories, running processes, and services and can manipulate directories and files, move file source to destination, terminate processes, restart and delete services, and more.

APT name	Regions attacked	Operation start
Machete	Venezuela	2019

In June 2020, security specialists discovered Fpyark, a new backdoor written in Python by a fileless attack protection function. Through in-depth examination and trace analysis, the specialists discovered a series of advanced threat actions that had been active since 2019. By intruding into various military institutions in Venezuela, the attackers deployed a backdoor to continuously monitor and steal military secrets. The malicious activity was attributed to APT-C-43 and the campaign was dubbed HpReact.

The APT-C-43 group launches attacks using phishing emails and deploys the Fpyark (Machete) backdoor, written in Python, after intruding into their victim's machine. The network communication mainly relies on FTP and HTTP protocols.

The decoy document is a policy issued by the Venezuelan authorities to prevent deserters from going to Colombia to support the reactionary government.

The decoy document carries malicious macrocode, which downloads the next stage of the malicious component NisSrv.bat through the FTP protocol.

NisSrv.bat downloads malicious components — "setupXOX.msi." The file "setupXOX.msi" is a Windows Installer installation program created by MSI Wrapper to deploy the final backdoor components. Many fields in the installation program are forged into the Acrobat Reader installation program.

After the program runs, Fpyark backdoor components will be put in the %ProgramData%\USOEnable directory.

The file “setupXOX.msi” is a virus releaser written in the Microsoft Visual Basic language, which releases NisSrv.bat registered scheduled tasks to implement self-starting and staying.

The backdoor’s main modules are:

- UpdateSession, which is the main control module of the backdoor. Its functions include backdoor self-starting, collection of network configuration, keystroke records, and scheduled execution of other modules using timers.
- UpdateService, which traverses the disk directory and collects more than ten kinds of sensitive files with suffixes such as .doc, .xlsx, and .pdf in other directories, except for some system directories and security software directories.
- UpdateDevice, which takes screenshots.
- UpdatePlugin, which receives audio from the microphone.
- Notification, which is responsible for uploading sensitive data collected by the above modules to an FTP server.

When analyzing the FTP server, the experts found that APT-C-43 managed uploaded sensitive files through Tiny File Manager.

In the process of tracing the source, the experts linked the campaign to the APT group Machete. Machete can be traced back to 2010. The group has Spanish roots and its targets are the military, embassies, and government agencies in Latin America.

APT name	Regions attacked	Operation start
TAIDOOR	Global	2008

The US Department of Defence (DoD), the Federal Bureau of Investigation (FBI), and the Cybersecurity and Infrastructure Security Agency (CISA) released a report about a recently detected remote access Trojan (RAT) called TAIDOOR, which has been actively used by the Chinese government for the purposes of cyber espionage.

“China’s Taidoor malware has been compromising systems since 2008,” announced the US Cyber Command, according to which TAIDOOR is used in attacks against governments, corporations, and think tanks.

According to Florian Roth, a malware analyst at Nextron Systems, another name for this malware is the Taurus RAT.

In their most recent alert, the three US government agencies say that they have spotted Taidoor being used in new attacks. The new Taidoor samples have versions for 32- and 64-bit systems and are usually installed on victims' systems as a service dynamic link library (DLL), according to the joint alert.

This DLL file, in turn, contains two other files.

The first file is a loader, which is started as a service. The loader decrypts the second file and executes it in memory, which is the main remote access Trojan (RAT).

The Taidoor RAT is then used to allow Chinese hackers to access infected systems and exfiltrate data or deploy other malware — activities for which remote access Trojans are typically used.

Data leaks

- On July 12, 2020, a post was made on xss.is, a forum, about the sale of the database of a major US IT company. According to the information provided, the database belongs to Citrix Systems, Inc. The threat actor highlighted that they were only selling the database and did not provide information about shells loaded and vulnerabilities used. The database contains about 2 million entries.
- In July, the financial company Dave informed its customers about a data leak. Data on a total of 7,516,625 users, which included real names, phone numbers, email addresses, dates of birth, and home addresses, was published online. The security breach was the fault of the company's former business partner, Waydev analytics platform. Allegedly, due to negligence on the part of Waydev, attackers were able to gain unauthorized access to data about Dave's users. The data was published on the Raidforums forum. The Shiny Hunters group is believed to be behind the incident.
- In July, CouchSurfing, a homestay service, suffered a breach of data on 17 million users. The database was sold on hacker forums and Telegram channels for $700. It includes data, such as user IDs, real names, email addresses, and CouchSurfing account settings. There are no passwords in the dump; however, the leaked information can be used for email spam.
- Security researcher Bob Diachenko discovered another unprotected client database of Razer, a gaming equipment manufacturer. The database affected 100,000 customers and included full names, email addresses, phone numbers, order details, and billing and shipping addresses. The researcher said that he could not reach the right people in the company for several weeks, until Razer addressed the problem and secured the database on September 9, 2020. The company underscored that no card numbers or passwords were exposed.
- In late September, a 42.9-GB torrent file, which included source code for several operating systems, such as Windows XP and Windows Server 2003, was published online. The person who published the file claims to have spent two months building this torrent. Experts note that nothing fatal happened, because many of the published files leaked into the network many years ago, and the new "leak" is in fact a collection of that data. The only new elements that have not been seen in the public domain before are the source codes for Windows XP, Server 2003, and Windows 2000.
- Ata Hakcil, a security researcher at WizCase, discovered that Microsoft had accidentally left one of Bing's backend servers exposed online. According to Hakcil's investigation, the server is believed to have exposed more than 6.5 TB of log files containing 13 billion records originating from the Bing search engine. The server was exposed online from September 10 to September 16, 2020, when the researcher notified Microsoft Security Response Center (MSRC) and the server was secured again with a password.
- An exposed repository belonging to the Indian state of Uttar Pradesh was discovered. The repository contained data on eight million people tested for COVID-19. The exposed data included full names, age, residence addresses, phone numbers, and medical information.
- Experts at Comparitech discovered an exposed database of the company Social Data containing YouTube, TikTok, and Instagram data. The data included names, contact and personal information, images, and statistics about followers. Overall, the database contained 235 million social media profiles. A Social Data spokesperson said that nothing bad happened, since the users made their profiles public themselves.
- Researchers at vpnMentor discovered data on over 20 million users of free VPN services exposed online. The leak affected UFO VPN, Fast VPN, Free VPN, Super VPN, Flash VPN, Secure VPN, and Rabbit VPN. An unsecured server contained 1.2 TB of user data, including email addresses, clear-text passwords, home addresses, phone models, and device IDs. Apart from data leaks, free VPN services can be risky because if a server has been created and is controlled by threat actors, they

will be able to intercept all user traffic, redirect it to phishing websites, and collect unencrypted data, which is how passwords, correspondence and other information can be leaked. Secondly, there have been cases of spyware being disguised as VPN apps; e.g., spyware mimicking the VPN service of a well-known integrator.